EJERCICIO PRÁCTICO · ARQUITECTURA DE SOLUCIONES

Diseño de Arquitectura del Sistema de Banca por Internet

Entidad Financiera BP · Modelo C4 (Contexto, Contenedores y Componentes) · Despliegue en AWS

Documento: Diseño de arquitectura de solución – Banca por Internet BP

Versión: 1.0 | **Fecha:** 25 de septiembre de 2026 | **Estado:** Propuesta para revisión

Elaborado por: Arquitecto de Soluciones – Proyecto Banca Digital BP

Audiencia: Comité de Arquitectura, Seguridad de la Información, Cumplimiento, Tecnología y Operaciones de BP

Repositorio público (GitHub): `https://github.com/<usuario>/bp-banca-internet-c4`

Resumen del entregable. Este documento presenta la arquitectura propuesta para la nueva plataforma de banca por internet de BP (canal web y canal móvil), con capacidad de consultar el histórico de movimientos, realizar transferencias y pagos entre cuentas propias e interbancarias, notificar cada movimiento por al menos dos canales, registrar a nuevos clientes mediante Onboarding con reconocimiento facial y auditar todas las acciones del cliente. Se describe con el modelo C4 hasta el nivel de componentes, se complementa con diagramas de secuencia y de despliegue en AWS, y cada decisión relevante se sustenta con al menos dos justificaciones teóricas y las alternativas evaluadas.

Los diagramas se generaron como código (PlantUML + C4 model) y se incluyen en alta resolución; amplíe con el zoom del visor para leer el detalle. Los archivos fuente (.puml), PNG y SVG se entregan en el repositorio.

Contenido

1. Resumen ejecutivo 3

2. Alcance, supuestos y requerimientos 4

2.1 Enunciado y alcance de la solución 4

2.2 Supuestos y restricciones 4

2.3 Requerimientos funcionales. 5

2.4 Requerimientos no funcionales (atributos de calidad) 5

3. Principios y estilo de arquitectura 7

4. Vista de contexto (C4 – Nivel 1) 8

5. Vista de contenedores (C4 – Nivel 2) 11

5.1 Diagrama general de contenedores. 11

5.2 Catálogo de contenedores y justificación tecnológica 12

5.3 Vista de detalle A: flujo síncrono (consultas y transacciones) 14

5.4 Vista de detalle B: flujo asíncrono (eventos, auditoría, notificaciones) 15

6. Vista de componentes (C4 – Nivel 3) 17

6.1 Servicio de Transferencias y Pagos + capa de integración 17

6.2 Autenticación y autorización (App Móvil, Web SPA e IdP). 19

6.3 Onboarding digital con reconocimiento facial 21

6.4 Solución de auditoría de acciones del cliente. 22

6.5 Persistencia de información para clientes frecuentes 25

6.6 Servicios de consulta y notificaciones 27

7. Arquitectura de front-end: Web SPA y App Móvil 28

8. Autenticación y autorización con OAuth 2.0 / OpenID Connect. 30

9. Onboarding digital con reconocimiento facial 34

10. Acceso a datos e integración con el Core y sistemas externos 37

11. Notificación de movimientos por múltiples canales 41

12. Infraestructura en AWS: alta disponibilidad, DR, latencia y auto-healing 42

13. Seguridad y cumplimiento normativo 46

14. Monitoreo, observabilidad y excelencia operativa 48

15. Gestión de costos (FinOps) 51

16. Registro de decisiones de arquitectura (ADR) 53

17. Riesgos y hoja de ruta 55

18. Conclusiones 56

Anexo A. Glosario 57

Anexo B. Referencias y estándares 58

Anexo C. Inventario de diagramas y contenido del repositorio 59

1. Resumen ejecutivo

BP requiere una plataforma de banca por internet moderna, segura y regulada que permita a sus clientes consultar el histórico de movimientos, realizar transferencias y pagos entre cuentas propias e interbancarias, recibir la notificación de cada movimiento y registrarse desde el móvil mediante reconocimiento facial. La solución propuesta es una **arquitectura cloud-native en AWS, basada en microservicios desacoplados y orientada a eventos**, expuesta a dos canales (una **Web SPA en Angular** y una **App Móvil multiplataforma en Flutter**) a través de un **API Gateway** y de **Backends for Frontend (BFF)**, e integrada con el Core Bancario, el sistema de información complementaria del cliente (CRM), el servidor de identidad corporativo (OAuth 2.0 / OIDC), el motor antifraude, la red de pagos interbancarios y los proveedores de notificación y verificación biométrica mediante una **capa de integración con API Gateway y conectores anticorrupción (ACL)**.

Las decisiones estructurales más relevantes son:

- **Nube AWS** (región primaria `us-east-1`, recuperación ante desastres en `us-east-2`), con despliegue Multi-AZ activo-activo, **DR warm standby** (RTO ≤ 30 min, RPO ≤ 1 min) y conectividad privada redundante con el data center de BP (AWS Direct Connect + VPN).
- **Microservicios en Amazon EKS con service mesh (Istio)**, uno por contexto de negocio (Clientes, Productos y Saldos, Movimientos, Transferencias y Pagos, Beneficiarios, Perfil Digital, Onboarding, Auditoría, Notificaciones), con base de datos por servicio y patrones **Saga, Transactional Outbox, Idempotent Receiver, Circuit Breaker, BFF, CQRS y Anti-Corruption Layer**.
- **Autenticación con OAuth 2.0 / OIDC usando el flujo Authorization Code + PKCE** (perfil FAPI 2.0 con PAR y DPoP), configurado sobre el IdP existente de BP: en la app móvil como cliente público con AppAuth (RFC 8252) y en la SPA a través del BFF con el patrón *Token Handler* (el navegador nunca custodia tokens). MFA con FIDO2 / passkeys y **step-up** (autenticación reforzada) para transacciones.
- **Onboarding con reconocimiento facial** integrado al flujo de identidad: Amazon Textract (OCR de cédula), Amazon Rekognition Face Liveness + CompareFaces (prueba de vida y comparación facial) tras un adaptador intercambiable, validación en Registro Civil y listas AML/PEP, alta en Core/CRM y enrolamiento de credenciales (clave, huella / rostro) en el IdP mediante SCIM y FIDO2.
- **Auditoría inmutable** de todas las acciones del cliente: eventos capturados por interceptores y outbox, canalizados por Kafka (Amazon MSK) a un servicio de auditoría en una cuenta AWS separada, con cadena de hashes firmada, base append-only (Aurora), archivo WORM en S3 Object Lock e índice de búsqueda en OpenSearch.
- **Persistencia para clientes frecuentes** mediante los patrones Repository + Strategy, Cache-Aside + Decorator (Redis), Observer (eventos de uso), Materialized View / CQRS (DynamoDB) y Refresh-Ahead, con invalidación por eventos del Core.
- **Notificación de cada movimiento por al menos dos canales**: Amazon SNS/SES (push, SMS, correo) y Twilio / WhatsApp Business como canal alterno, con cadena de contingencia y evidencia de entrega.
- **Seguridad y cumplimiento** alineados con la LOPDP de Ecuador, la normativa de la Superintendencia de Bancos (riesgo operativo y canales electrónicos), la Ley de prevención de lavado de activos, PCI DSS 4.0, ISO/IEC 27001, NIST CSF 2.0, NIST SP 800-63B, OWASP ASVS / MASVS y FAPI 2.0.
- **Observabilidad y excelencia operativa**: OpenTelemetry, Amazon Managed Prometheus / Grafana, CloudWatch, X-Ray, SLOs con error budgets, auto-healing en Kubernetes, runbooks automatizados e ingeniería de caos; entrega continua con IaC (Terraform) y GitOps.
- **Costos** gestionados con prácticas FinOps; la estimación referencial de operación es de USD 14.000–16.000 mensuales (incluyendo DR y Shield Advanced), a validar con AWS Pricing Calculator.

El documento se organiza siguiendo el modelo C4: contexto (sección 4), contenedores (sección 5) y componentes (sección 6); luego profundiza en cada criterio del ejercicio (front-end, autenticación, Onboarding, datos e integración, notificaciones, infraestructura, seguridad y cumplimiento, monitoreo y costos), consolida el registro de decisiones (sección 16) y cierra con riesgos, hoja de ruta y conclusiones.

2. Alcance, supuestos y requerimientos

2.1 Enunciado y alcance de la solución

BP contrató el diseño de un sistema de banca por internet que debe permitir a sus clientes: (a) consultar el histórico de movimientos de sus productos; (b) realizar transferencias y pagos entre cuentas propias y hacia cuentas de otras entidades (interbancarias); (c) recibir la notificación de cada movimiento por al menos dos sistemas de notificación (propios o externos); (d) registrarse desde la app móvil mediante Onboarding con reconocimiento facial y, a partir de entonces, ingresar con usuario y clave, huella u otro método; y (e) contar con un registro de auditoría de todas las acciones del cliente. La información del cliente proviene de dos fuentes: el **Core Bancario** (datos básicos, productos y movimientos) y un **sistema independiente de información complementaria** que se consulta cuando se requiere el detalle del cliente.

Están en el alcance de este diseño: los dos front-ends (Web SPA y App Móvil), los BFF y microservicios de negocio, la capa de integración (API Gateway de integración y conectores hacia Core, CRM, red interbancaria, IdP, antifraude, Registro Civil y listas de control), la solución de autenticación / autorización sobre el IdP existente, el Onboarding facial, la auditoría, la persistencia para clientes frecuentes, el subsistema de notificaciones, la infraestructura en la nube, la seguridad, el monitoreo, la operación y los costos. Quedan fuera del alcance el rediseño interno del Core Bancario, del CRM y del IdP (se consumen como sistemas existentes) y la consola de administración de back-office, que se menciona solo como consumidor de la auditoría.

2.2 Supuestos y restricciones

ID	Supuesto / restricción	Descripción e impacto en el diseño
SUP-01	Jurisdicción	BP opera en **Ecuador**; se toma como marco regulatorio de referencia la Ley Orgánica de Protección de Datos Personales (LOPDP), el Código Orgánico Monetario y Financiero (COMF), la normativa de la Superintendencia de Bancos y del Banco Central (SPI) y la Ley de prevención de lavado de activos. Se indican equivalentes regionales e internacionales para facilitar la adaptación a otra jurisdicción (sección 13).
SUP-02	Nube pública	El enunciado permite Azure o AWS con baja latencia y existe presupuesto. Se selecciona **AWS** (sección 12, decisión D-16). El Core, el CRM, el IdP y el motor antifraude permanecen en el data center de BP y se conectan por enlaces privados.
SUP-03	IdP existente	BP posee un producto de identidad configurable como Authorization Server OAuth 2.0 / OIDC (p. ej. ForgeRock/Ping, Keycloak, Okta, Entra ID). El diseño no depende de un producto concreto: usa únicamente estándares (OIDC Discovery, PAR, PKCE, DPoP, JWKS, SCIM 2.0, WebAuthn).
SUP-04	APIs del Core y del CRM	Ambos sistemas exponen servicios (REST y/o SOAP) para consultar datos básicos, productos, saldos y movimientos, crear clientes y ejecutar débitos / créditos. Si el Core no publica eventos, el flujo de cambios (CDC) se obtiene desde una réplica de lectura autorizada.
SUP-05	Red interbancaria	Las transferencias interbancarias se cursan por la red de pagos (ACH / SPI del BCE) con mensajería ISO 20022 (pacs.008 / pacs.002) o el formato exigido por la red, con confirmación asíncrona.
SUP-06	Volumen de referencia	Dimensionamiento inicial: 500.000 clientes, 50.000 usuarios activos mensuales, 50 millones de peticiones / mes, pico de 300 transacciones / s en fechas de pago. Todos los componentes escalan horizontalmente.
SUP-07	Antifraude	BP cuenta (o contratará) con un motor antifraude que devuelve un puntaje de riesgo en línea; se integra como sistema externo con tiempo máximo de respuesta acotado.
RES-01	Modelo C4	La arquitectura de aplicación se documenta hasta el nivel de componentes; la infraestructura se modela libremente (diagrama de despliegue).
RES-02	Presupuesto	Existe presupuesto para servicios gestionados y DR multi-región; aun así se aplican prácticas FinOps (sección 15).

2.3 Requerimientos funcionales

ID	Requerimiento	Detalle y trazabilidad al diseño
RF-01	Consultar histórico de movimientos	Movimientos por producto con filtros (fechas, tipo, monto) y paginación; datos del Core, enriquecidos con el CRM cuando se requiere detalle. → Servicio de Movimientos, Servicio de Clientes (§5, §6.5, §10).
RF-02	Transferencias entre cuentas propias	Débito y crédito atómicos en el Core, con validación de límites y saldo en línea. → Servicio de Transferencias y Pagos (§6.1).
RF-03	Transferencias y pagos interbancarios	Orden hacia la red ACH / SPI, estado asíncrono, compensación ante rechazo, gestión de beneficiarios. → §6.1, §10.
RF-04	Notificar cada movimiento	Toda transacción genera una notificación por al menos dos canales (push / SMS / correo / WhatsApp) según preferencia del cliente, con evidencia de entrega. → Servicio de Notificaciones (§6.6, §11).
RF-05	Canal Web (SPA)	Aplicación web de una sola página, responsiva y accesible. → §7.
RF-06	Canal móvil multiplataforma	App iOS y Android con un solo código base; biometría, notificaciones push, Onboarding. → §7.
RF-07	Autenticación OAuth 2.0 / OIDC	Uso del IdP existente; flujo recomendado según el estándar; login con usuario/clave, huella / rostro (FIDO2) u otro método; MFA y step-up. → §6.2, §8.
RF-08	Onboarding con reconocimiento facial	Registro de clientes nuevos desde el móvil con captura de documento, prueba de vida y comparación facial, validación de identidad, alta en Core/CRM y creación de credenciales. → §6.3, §9.
RF-09	Auditoría de acciones	Registro inmutable de toda acción del cliente (quién, qué, cuándo, desde dónde, resultado), consultable por cumplimiento y reportable al regulador. → §6.4.
RF-10	Persistencia para clientes frecuentes	Mecanismo basado en patrones de diseño que acelera la consulta de clientes con uso recurrente sin comprometer la consistencia. → §6.5.
RF-11	Capa de integración	API Gateway de integración y servicios de consulta de datos básicos, consulta de movimientos y transferencias (que invoca servicios externos según el tipo), extensible a nuevos servicios (beneficiarios, productos, perfil). → §5, §10.
RF-12	Gestión de dispositivos y sesiones	Vinculación de dispositivos, cierre remoto de sesiones, límites configurables por canal. → §8.

2.4 Requerimientos no funcionales (atributos de calidad)

ID	Atributo	Objetivo medible	Tácticas de arquitectura
RNF-01	Disponibilidad	≥ 99,95 % mensual para consultas y transferencias (≤ 22 min de indisponibilidad / mes), 24×7.	Multi-AZ activo-activo, servicios gestionados, sin puntos únicos de falla, DR warm standby, degradación controlada (§12).
RNF-02	Rendimiento / latencia	p95 < 500 ms y p99 < 800 ms en consultas; p99 < 2 s en transferencias (excluyendo la red interbancaria); TTFB web < 200 ms.	Región cercana (us-east-1), CDN + Global Accelerator, caché Redis, vistas materializadas, gRPC interno, conexiones persistentes al Core (§10, §12).
RNF-03	Escalabilidad	Escalado horizontal automático de 300 a 3.000 tx/s sin cambios de diseño.	Microservicios sin estado, HPA / KEDA / Karpenter, particionamiento Kafka, DynamoDB on-demand, Aurora Serverless v2 / réplicas de lectura.
RNF-04	Tolerancia a fallos	La caída de una AZ o de un microservicio no afecta al cliente; la caída del Core degrada a modo lectura con datos recientes (stale-while-revalidate) y rechaza transacciones de forma segura.	Circuit breaker, bulkhead, timeouts, reintentos idempotentes, colas con DLQ, saga con compensación (§6.1, §10, §12).
RNF-05	Recuperación ante desastres	RTO ≤ 30 min, RPO ≤ 1 min (transaccional) y RPO = 0 para auditoría (multi-región síncrona por diseño de Kafka + S3 CRR).	Aurora Global Database, DynamoDB Global Tables, Redis Global Datastore, MSK Replicator, S3 CRR, IaC idéntico, pruebas de DR trimestrales (§12).

ID	Atributo	Objetivo medible	Tácticas de arquitectura
RNF-06	Seguridad	Cumplimiento OWASP ASVS nivel 2 (nivel 3 en autenticación y transacciones), MASVS-L2 + R en móvil, cifrado extremo a extremo, cero tokens en el navegador, MFA obligatoria.	Zero Trust, mTLS, FAPI 2.0, DPoP, KMS / CloudHSM, WAF, Shield Advanced, GuardDuty, DevSecOps (§8, §13).
RNF-07	Cumplimiento y auditabilidad	100 % de las acciones del cliente auditadas; integridad verificable; retención configurable (por defecto 10 años); reportes al regulador en formato requerido.	Outbox + cadena de hashes firmada + WORM + cuenta separada (§6.4, §13).
RNF-08	Privacidad	Minimización y enmascaramiento de PII en logs, consentimiento explícito para biometría, derechos ARCO, residencia y cifrado de datos.	Tokenización, cifrado a nivel de campo, políticas de retención, DLP con Amazon Macie (§13).
RNF-09	Observabilidad	MTTD < 5 min y MTTR < 30 min para incidentes de severidad 1; trazabilidad extremo a extremo por trace-id.	OpenTelemetry, métricas RED / USE, SLOs y alertas por síntoma, runbooks (§14).
RNF-10	Mantenibilidad y reutilización	Servicios desacoplados y reutilizables por nuevos canales (p. ej. banca corporativa, open finance); despliegues independientes diarios sin ventana de mantenimiento.	API-first (OpenAPI / AsyncAPI), contratos versionados, arquitectura hexagonal, CI/CD con canary / blue-green (§3, §14).
RNF-11	Costo	Costo operativo alineado al crecimiento; visibilidad por servicio y por canal; optimización continua.	FinOps: Savings Plans, Graviton, right-sizing, lifecycle de datos, presupuestos y alertas (§15).
RNF-12	Usabilidad y accesibilidad	WCAG 2.2 AA en web; guías de accesibilidad iOS / Android en móvil; Onboarding completable en < 5 min.	Design system compartido, pruebas de usabilidad, telemetría RUM (§7).

3. Principios y estilo de arquitectura

El diseño se rige por los siguientes principios, que orientan todas las decisiones de las secciones posteriores:

1. **Desacoplamiento y responsabilidad única.** Cada capacidad de negocio (consulta de clientes, movimientos, transferencias, onboarding, auditoría, notificaciones, perfil digital) es un servicio independiente con su propia base de datos (*database per service*) y contratos explícitos; las dependencias fluyen a través del API Gateway y del bus de eventos, nunca por acceso directo a datos ajenos.
2. **API-first y contratos versionados.** Las interfaces se diseñan antes que la implementación (OpenAPI 3 para REST, AsyncAPI para eventos, Protobuf para gRPC interno) y se versionan de forma compatible, lo que habilita la reutilización por futuros canales.
3. **Arquitectura orientada a eventos (EDA) con consistencia eventual controlada.** Los hechos de negocio (transferencia aceptada, cliente registrado, acceso realizado) se publican como eventos inmutables; la auditoría, las notificaciones y el perfil de clientes frecuentes se construyen sin acoplar los flujos transaccionales.
4. **Seguridad por diseño y Zero Trust.** Ninguna llamada es confiable por su origen de red: identidad verificada (JWT / mTLS) en cada salto, mínimo privilegio, cifrado en tránsito y en reposo, secretos gestionados y auditoría completa.
5. **Resiliencia: diseñar para fallar.** Redundancia en todas las capas, aislamiento de fallos (bulkheads), degradación elegante, operaciones idempotentes y compensación transaccional.
6. **Servicios gestionados primero.** Se prefieren servicios gestionados de AWS (EKS, Aurora, MSK, DynamoDB, ElastiCache, OpenSearch, KMS) para reducir la carga operativa, con estándares abiertos (Kubernetes, PostgreSQL, Kafka, Redis, OpenTelemetry) que limitan el bloqueo tecnológico.
7. **Todo como código y observabilidad integrada.** Infraestructura, pipelines, políticas y diagramas se versionan; cada servicio expone métricas, logs estructurados y trazas desde su primera versión.
8. **Cumplimiento verificable.** Los controles regulatorios (LOPDP, riesgo operativo, AML, PCI DSS) se implementan como controles técnicos evidenciables y automatizados (AWS Config, Security Hub, auditoría inmutable).

Decisión D-01 · Estilo arquitectónico: microservicios en contenedores con orientación a eventos

Opciones evaluadas: (a) monolito modular desplegado en contenedores; (b) microservicios en Kubernetes (EKS) con service mesh; (c) arquitectura serverless pura (API Gateway + Lambda + DynamoDB).

Selección: (b) microservicios en Amazon EKS, complementados con serverless (Lambda / SQS) para cargas asíncronas de baja complejidad como notificaciones.

Justificaciones:

1. **Segmentación de responsabilidades y escalado independiente:** la carga de consultas (alta, de lectura) y la de transferencias (menor, crítica y transaccional) tienen perfiles distintos; separarlas evita que un pico de consultas afecte a las transacciones (aislamiento de fallos – principio de *bulkhead*), algo que un monolito no puede garantizar aunque sea modular.
2. **Desacoplamiento y reutilización exigidos por el enunciado:** los servicios de consulta de datos básicos, movimientos y transferencias quedan expuestos como capacidades reutilizables por cualquier canal actual o futuro (open finance, banca corporativa, asistentes conversacionales) detrás del API Gateway.
3. **Madurez operativa y portabilidad:** Kubernetes es un estándar abierto con herramientas maduras de auto-healing, despliegue progresivo y observabilidad; el modelo serverless puro fue descartado como base por los límites de duración / conexiones para procesos transaccionales largos (sagas, conexiones persistentes al Core vía Direct Connect), el arranque en frío en la ruta crítica y el mayor acoplamiento al proveedor.

Consecuencias: mayor complejidad operativa (mitigada con EKS gestionado, Istio, GitOps y plantillas de servicio) y necesidad de gobernanza de contratos y de datos distribuidos (mitigada con Saga / Outbox y catálogo de eventos).

4. Vista de contexto (C4 – Nivel 1)

El diagrama de contexto sitúa al **Sistema de Banca por Internet BP** en su entorno: las personas que lo usan, los sistemas internos de BP con los que colabora y los sistemas externos de los que depende. La convención C4 emplea recuadros de **persona**, **sistema de software** (azul) y **sistema externo** (gris), unidos por relaciones etiquetadas con el propósito y el protocolo.

4.1 Actores

Actor	Descripción y objetivos	Interacción principal
Cliente BP	Persona natural con productos en BP. Consulta saldos e histórico de movimientos, transfiere entre cuentas propias, paga y transfiere a otros bancos, administra beneficiarios y recibe notificaciones.	Web SPA y App Móvil (HTTPS / TLS 1.3).
Cliente nuevo	Persona que aún no es cliente y se registra desde la app móvil mediante Onboarding digital con reconocimiento facial.	App Móvil (cámara, SDK de prueba de vida).
Operador BP / Oficial de Cumplimiento	Personal interno que monitorea la plataforma, parametriza límites y canales, atiende casos en revisión (Onboarding, fraude) y consulta la auditoría.	Consola interna (fuera de alcance detallado), API de auditoría con RBAC.
Regulador / Auditor externo	Superintendencia de Bancos, UAFE y auditoría externa: reciben reportes y verifican la integridad de los registros.	Reportes periódicos (SFTP cifrado / portal), verificación de cadena de hashes.

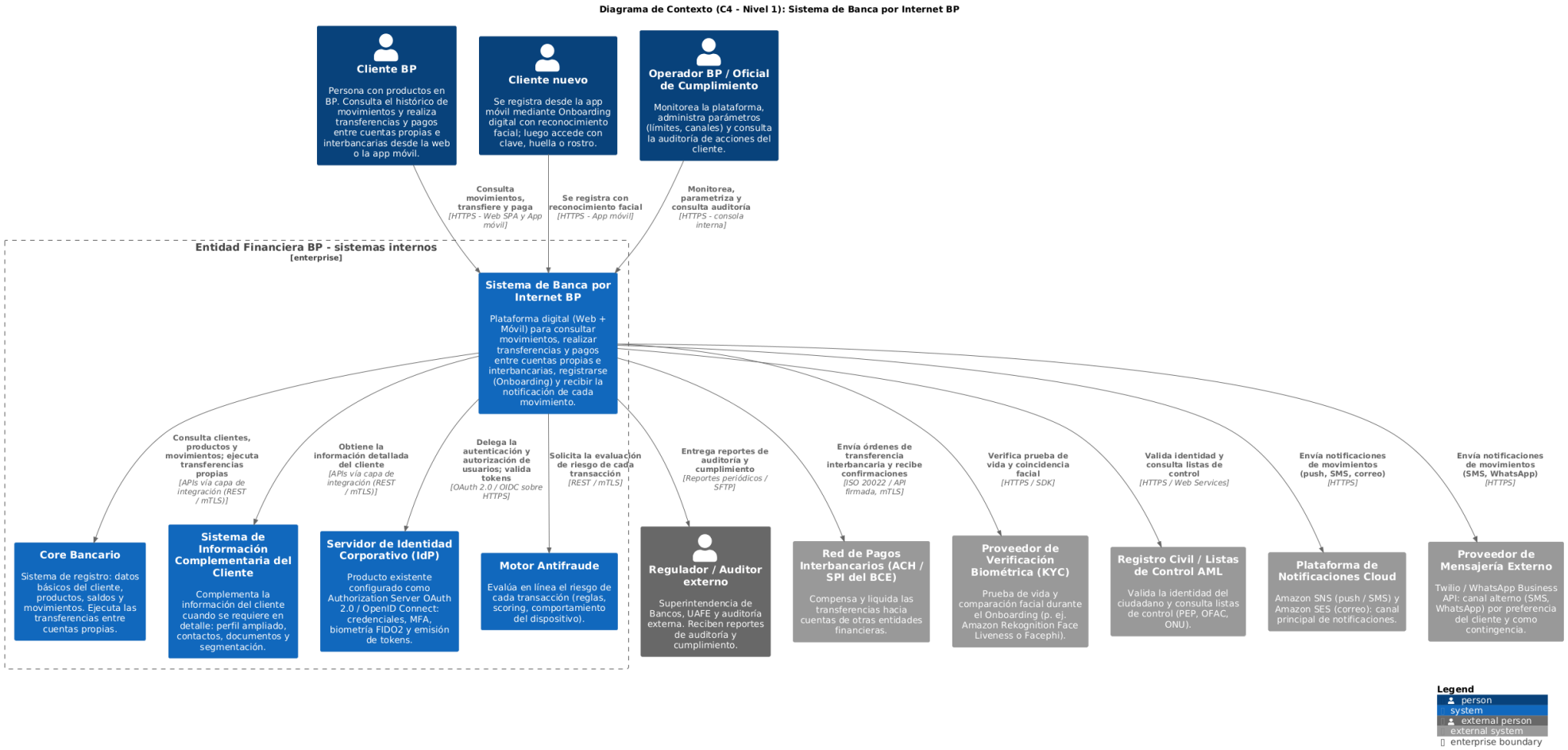


Figura 1. *Diagrama de contexto (C4 – Nivel 1) del Sistema de Banca por Internet BP.*

Confidencial – uso académico

4.2 Sistemas internos y externos

Sistema	Tipo	Rol en la solución y protocolo de integración
Core Bancario	Interno	Sistema de registro: datos básicos del cliente, productos, saldos, movimientos; ejecuta débitos / créditos y transferencias entre cuentas propias. Integración REST / SOAP sobre mTLS a través del API Gateway de integración y conectores ACL (Direct Connect).
Sistema de Información Complementaria (CRM)	Interno	Sistema independiente que complementa el detalle del cliente (perfil ampliado, contactos, documentos, segmentación). Se consulta solo cuando se requiere detalle; REST sobre mTLS.
Servidor de Identidad Corporativo (IdP)	Interno	Producto existente configurado como Authorization Server OAuth 2.0 / OIDC: usuarios, credenciales, MFA, biometría FIDO2, emisión y revocación de tokens. Protocolos: OIDC, PAR, DPoP, JWKS, SCIM 2.0, WebAuthn.
Motor Antifraude	Interno	Evalúa en línea el riesgo de cada transacción (reglas, scoring, huella del dispositivo). REST sobre mTLS con tiempo máximo acotado.
Red de pagos interbancarios (ACH / SPI del BCE)	Externo	Compensación y liquidación de transferencias hacia otras entidades. Mensajería ISO 20022 (pacs.008 / pacs.002) firmada, sobre mTLS; confirmación asíncrona.
Proveedor de verificación biométrica (KYC)	Externo	Prueba de vida y comparación facial durante el Onboarding: Amazon Rekognition Face Liveness + CompareFaces como opción principal; Facephi / Incode como alternativas tras un adaptador intercambiable. HTTPS (SDK) con VPC endpoint.
Registro Civil / Listas de control AML	Externo	Validación de identidad del ciudadano (cédula, vigencia, foto) y consulta de listas PEP / OFAC / ONU / UAFE. Web services sobre mTLS.
Plataforma de notificaciones cloud (Amazon SNS / SES)	Externo	Canal principal de notificación: push (vía FCM / APNs), SMS y correo electrónico. HTTPS (SDK, IAM).
Proveedor de mensajería externo (Twilio / WhatsApp Business)	Externo	Segundo sistema de notificación: SMS y WhatsApp por preferencia del cliente y como contingencia si el canal principal falla. HTTPS (API con firma y webhooks de estado).

Decisión D-02 · Dos sistemas de notificación: Amazon SNS / SES (principal) + Twilio / WhatsApp Business (alterno)

Opciones evaluadas: (a) SNS + SES; (b) Twilio (SMS / WhatsApp) + SendGrid; (c) Amazon Pinpoint / AWS End User Messaging; (d) pasarela SMS local del operador más un servidor SMTP propio.

Selección: (a) como canal principal y (b) como canal alterno, orquestados por el Servicio de Notificaciones con una cadena de contingencia configurable por cliente.

1. **Cumplimiento del mandato normativo con independencia de proveedores:** la norma exige al menos dos sistemas de notificación; usar proveedores de distinta naturaleza (nube AWS y un SaaS especializado) elimina el punto único de falla comercial y técnico, y permite conmutar por canal según disponibilidad (patrón *Strategy* + *Chain of Responsibility*).
2. **Cobertura de canales y experiencia de cliente:** SNS / SES cubren push, SMS y correo con integración nativa IAM y costos bajos; Twilio / WhatsApp aportan el canal preferido en la región (WhatsApp) y entregabilidad SMS con rutas alternas, ambos con acuses de entrega que se conservan como evidencia.
3. **Alternativas descartadas:** Pinpoint está en proceso de transición de producto y su valor está en campañas de marketing, no en notificaciones transaccionales; una pasarela SMS local más SMTP propio incrementa la carga operativa y no ofrece SLAs comparables.

5. Vista de contenedores (C4 – Nivel 2)

5.1 Diagrama general de contenedores

El nivel de contenedores descompone el sistema en unidades desplegables independientes (aplicaciones, servicios, bases de datos y colas). La Figura 2 presenta la vista general con las agrupaciones lógicas: canales, borde y BFF, microservicios de negocio, capa de integración, mensajería, datos y plataforma. Para facilitar la lectura, las secciones 5.3 y 5.4 muestran dos vistas de detalle (flujo síncrono y flujo asíncrono) con las relaciones a nivel de cada servicio.

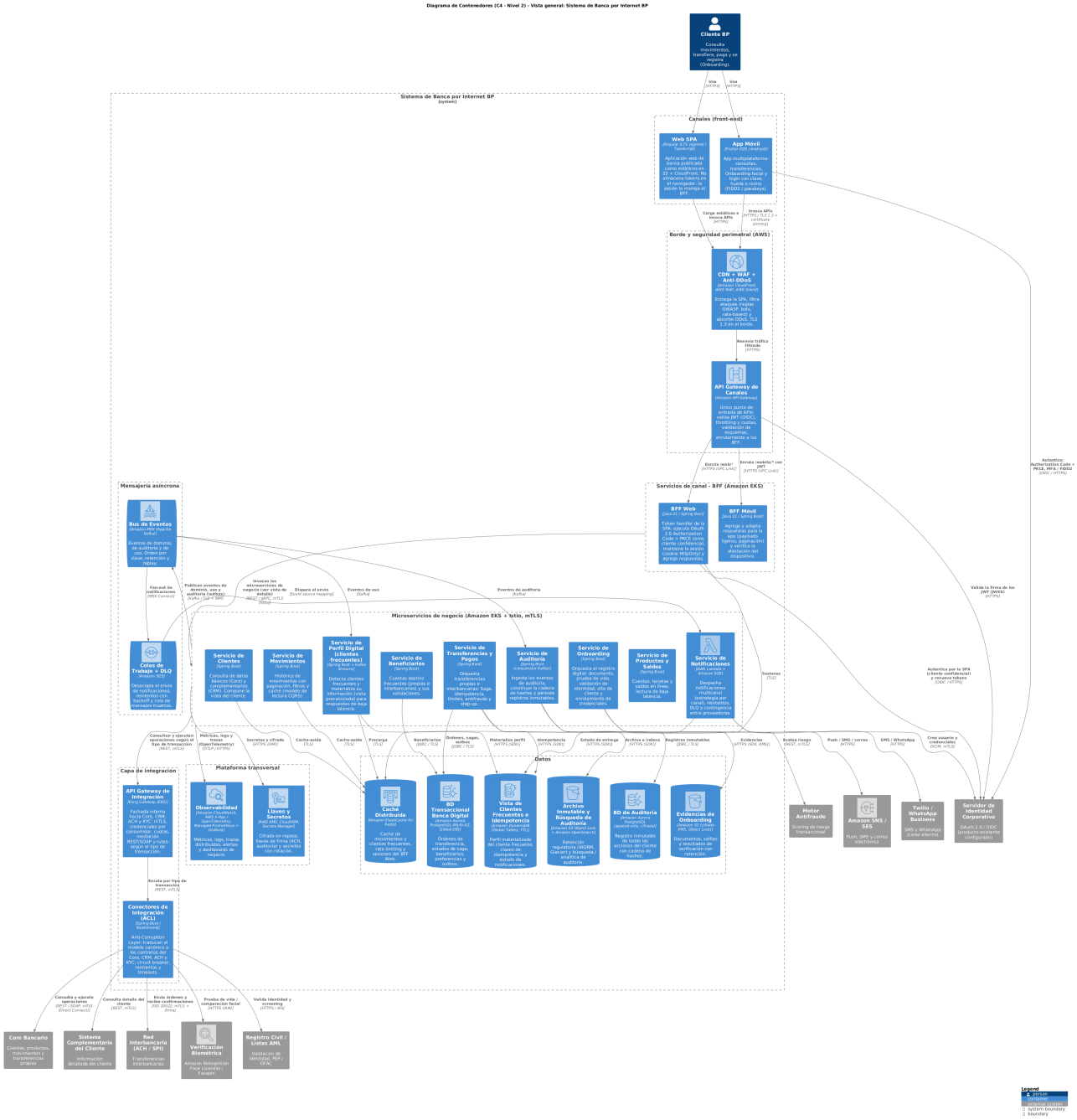


Figura 2. *Diagrama de contenedores (C4 – Nivel 2), vista general del Sistema de Banca por Internet BP.*

5.2 Catálogo de contenedores y justificación tecnológica

Contenedor	Tecnología	Responsabilidad	Justificación resumida (detalle en las secciones indicadas)
Web SPA	Angular (LTS vigente), TypeScript; estáticos en S3 + CloudFront	Banca web: consulta, transferencias, beneficiarios, preferencias. No custodia tokens (sesión vía BFF).	Framework opinado con seguridad integrada (sanitización, CSP / Trusted Types), tipado fuerte y LTS predecible (§7, D-07).
App Móvil	Flutter (Dart) para iOS y Android	Banca móvil, biometría / passkeys, Onboarding facial, notificaciones push, vinculación de dispositivo.	Un solo código compilado a nativo (AOT), UI consistente, ecosistema de seguridad (AppAuth, secure storage, pinning) (§7, D-08).
CDN + WAF + Shield	Amazon CloudFront, AWS WAF, Shield Advanced	Entrega de la SPA, terminación TLS 1.3, protección OWASP Top 10 / bots / DDoS, geo-restricción.	Borde global con baja latencia y protección gestionada 24×7 (§12, §13).
API Gateway de Canales	Amazon API Gateway (regional) + JWT Authorizer + WAF	Punto único de entrada de los canales: validación de JWT, cuotas, throttling, versionado, logs de acceso, integración privada con EKS (VPC Link).	Servicio gestionado, escalable, con autorización estándar y observabilidad nativa (D-04).
BFF Web / BFF Móvil	Spring Boot (Java 21) en EKS	Adaptan la API a cada canal (agregación, formato, paginación), ejecutan el patrón Token Handler (web) y aplican políticas por canal.	Patrón BFF: evita APIs genéricas sobredimensionadas y aísla la seguridad del navegador (§7, §8, D-05).
Servicio de Clientes	Spring Boot en EKS; Aurora PostgreSQL; Redis	Consulta de datos básicos del cliente (Core) y detalle (CRM); preferencias de canal; gestiona el consentimiento.	Servicio principal de consulta requerido por el enunciado; patrones Repository / Cache-Aside (§6.5).
Servicio de Productos y Saldos	Spring Boot en EKS; Redis	Lista de productos y saldos en línea; saldo pre-transacción siempre desde el Core.	Separado de Clientes para escalar la consulta más frecuente de forma independiente.
Servicio de Movimientos	Spring Boot en EKS; Redis; DynamoDB (vista)	Histórico de movimientos con filtros y paginación; combina Core y vista materializada para clientes frecuentes.	Segundo servicio principal del enunciado; CQRS para lecturas intensivas (§6.5, §10).
Servicio de Transferencias y Pagos	Spring Boot en EKS; Aurora PostgreSQL; DynamoDB (idempotencia)	Orquesta transferencias propias e interbancarias y pagos: validaciones, antifraude, saga con compensación, outbox.	Tercer servicio principal; llama a servicios externos según el tipo de transacción (§6.1).
Servicio de Beneficiarios	Spring Boot en EKS; Aurora	Alta / baja de beneficiarios con período de enfriamiento y confirmación por segundo canal.	Servicio adicional (permitido por el enunciado) que reduce el fraude de beneficiario nuevo.
Servicio de Perfil Digital (clientes frecuentes)	Spring Boot + Kafka Streams en EKS; DynamoDB; Redis	Detecta clientes frecuentes, materializa su perfil consolidado y lo mantiene actualizado por eventos.	Mecanismo de persistencia basado en patrones exigido por el enunciado (§6.5, D-11).
Servicio de Onboarding	Spring Boot en EKS; Aurora; S3 Object Lock	Máquina de estados del registro: consentimiento, OCR, prueba de vida, comparación facial, Registro Civil, AML, alta en Core / CRM, enrolamiento en IdP.	Integración con Onboarding facial exigida (§6.3, §9, D-12).
Servicio de Auditoría	Spring Boot en EKS (cuenta AWS separada); Aurora append-only; S3 Object Lock; OpenSearch	Consume todos los eventos de auditoría, los normaliza, encadena y firma, persiste de forma inmutable y expone consultas / reportes.	Diseño de auditoría con segregación de funciones e integridad criptográfica (§6.4, D-10).
Servicio de Notificaciones	AWS Lambda + Amazon SQS (DLQ)	Consume eventos de negocio, resuelve preferencias y plantillas, envía por dos canales con contingencia y guarda evidencia de entrega.	Serverless: carga asíncrona y elástica de baja complejidad; costo por uso (§11).
API Gateway de Integración + Conectores ACL	Kong Gateway + Spring Boot (adaptadores) en EKS	Mediación hacia Core, CRM, red ACH, IdP (SCIM), antifraude, Registro Civil y listas AML: mTLS por consumidor, transformación REST ↔ SOAP, ruteo por tipo de transacción, rate limiting, circuit breaker.	Capa de integración exigida; ACL protege el modelo de dominio del legado (§10, D-13).

Contenedor	Tecnología	Responsabilidad	Justificación resumida (detalle en las secciones indicadas)
Bus de eventos	Amazon MSK (Apache Kafka)	Tópicos: audit-events, usage-events, transfer-events, onboarding-events, core-cdc; retención y replay.	Durabilidad, orden por partición, múltiples consumidores y replicación multi-región (D-15).
Colas de trabajo	Amazon SQS + DLQ	Desacople de notificaciones y tareas; reintentos con back-off.	Simplicidad y costo para colas punto a punto.
BD transaccional	Amazon Aurora PostgreSQL (Multi-AZ, Global Database)	Órdenes, sagas, outbox, beneficiarios, estado de Onboarding (un esquema / clúster por servicio).	ACID, alta disponibilidad gestionada y replicación entre regiones (D-14).
Caché	Amazon ElastiCache for Redis (cluster mode, Global Datastore)	Caché L1 de clientes, sesiones del BFF, rate limiting distribuido.	Latencia sub-milisegundo y estructuras de datos ricas (D-14).
Vista de clientes frecuentes / idempotencia	Amazon DynamoDB (Global Tables, TTL)	Perfil consolidado por cliente y claves de idempotencia.	Lecturas por clave a escala con TTL nativo y replicación multi-región (D-14).
Auditoría (BD, WORM e índice)	Aurora (append-only), S3 Object Lock + Glacier, OpenSearch	Registros inmutables, archivo de largo plazo y búsqueda / analítica.	Separación de almacenamiento por propósito (§6.4).
Evidencias de Onboarding	Amazon S3 Object Lock + KMS	Documentos, selfies, puntajes y decisiones con retención regulatoria.	Inmutabilidad y cifrado por cliente.
Observabilidad	OpenTelemetry, CloudWatch, X-Ray, Managed Prometheus / Grafana	Métricas, logs, trazas, SLOs y alertas (§14).	Estándares abiertos + servicios gestionados.
Llaves y secretos	AWS KMS, CloudHSM, Secrets Manager, ACM	Cifrado, firma, certificados y secretos con rotación.	Requisito PCI DSS / ISO 27001 de gestión de llaves (§13).

Decisión D-03 · Comunicación interna: REST/JSON en el borde, gRPC entre microservicios y eventos por Kafka

Opciones evaluadas: (a) REST/JSON en todas las capas; (b) gRPC interno + REST externo; (c) mensajería asíncrona para todo.

Selección: (b) para llamadas síncronas, con eventos Kafka para todo lo que no requiera respuesta inmediata.

1. **Eficiencia y contratos fuertes:** gRPC (HTTP/2 + Protobuf) reduce latencia y ancho de banda entre servicios y genera contratos tipados verificables en compilación; REST/JSON se mantiene hacia los canales por su universalidad y por las capacidades del API Gateway (OpenAPI, JWT Authorizer, cuotas).
2. **Desacoplamiento temporal donde importa:** auditoría, notificaciones y perfil digital consumen eventos, por lo que la ruta transaccional no espera por ellos; esto mejora la tolerancia a fallos y la latencia percibida (RNF-02, RNF-04).
3. **Alternativa descartada:** hacer todo asíncrono complicaría los casos de uso de consulta que requieren respuesta inmediata y aumentaría la complejidad de la app.

Decisión D-04 · API Gateway de canales: Amazon API Gateway con JWT Authorizer (frente a Kong / Apigee / NGINX autogestionado)

1. **Servicio gestionado y elástico:** sin servidores que operar, escalado automático, integración privada con EKS por VPC Link, WAF nativo y logs / métricas integrados en CloudWatch, lo que reduce la superficie operativa (excelencia operativa).
2. **Autorización estándar en el borde:** valida JWT (firma vía JWKS, `iss`, `aud`, `exp`, `scope`) antes de que la petición toque un pod, con cuotas por cliente / plan de uso; los microservicios revalidan (defensa en profundidad).
3. **Separación de responsabilidades:** el gateway de canales (norte-sur, público) y el gateway de integración (Kong, este-oeste hacia sistemas legados) resuelven problemas distintos; Kong se elige para integración porque requiere mTLS por consumidor, plugins de transformación REST ↔ SOAP y despliegue dentro de la VPC junto a los conectores (§10, D-13).

Decisión D-05 · Patrón Backend for Frontend (BFF) por canal

1. **Adaptación por canal sin contaminar los servicios de dominio:** la web y el móvil requieren agregaciones, paginaciones y formatos distintos (p. ej. la pantalla de inicio móvil consolida saldos, últimos movimientos y notificaciones en una llamada); el BFF hace esa composición (patrón *API Composition*) y mantiene a los microservicios centrados en su dominio.
2. **Seguridad diferenciada:** el BFF Web implementa el patrón Token Handler (sesión en cookie HttpOnly, tokens en el servidor), mientras el BFF Móvil recibe tokens DPoP desde un cliente público; cada uno aplica las políticas de su canal (límites, verificación de dispositivo).
3. **Evolución independiente:** los equipos de canal despliegan su BFF sin coordinar con los equipos de dominio; se evita el "gateway inteligente" con lógica de negocio.

5.3 Vista de detalle A: flujo síncrono (consultas y transacciones)

La Figura 3 muestra, para la ruta síncrona, cómo cada BFF invoca a los servicios de negocio y cómo estos, a su vez, consultan la fuente de verdad a través del API Gateway de integración y de los conectores ACL. Se destaca que el saldo previo a una transferencia y las transacciones nunca se resuelven desde caché, y que la consulta del CRM solo ocurre cuando se requiere el detalle del cliente.

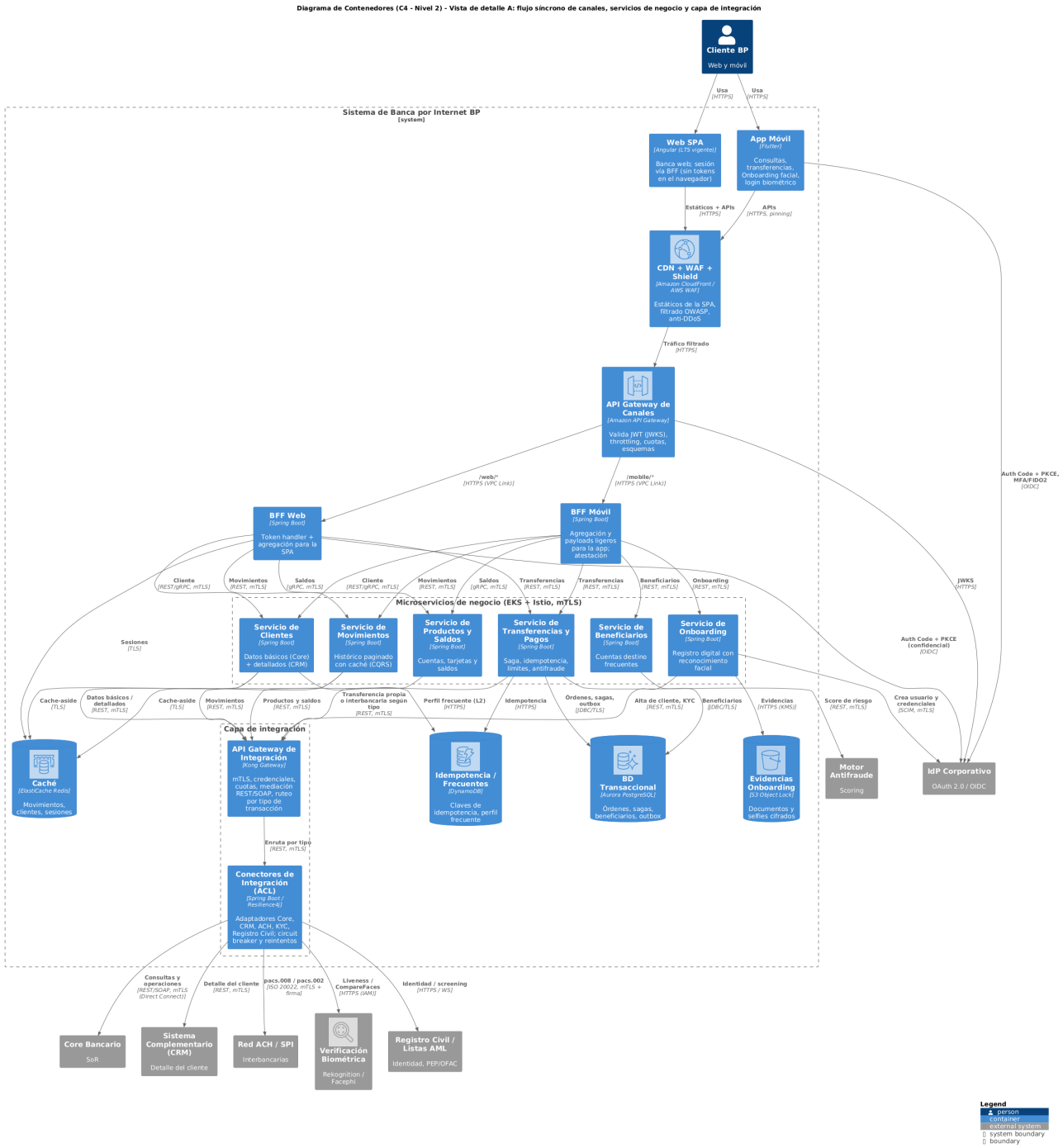


Figura 3. *Contenedores – vista de detalle A: flujo síncrono desde los canales hasta el Core, el CRM y la red interbancaria.*

5.4 Vista de detalle B: flujo asíncrono (eventos, auditoría, notificaciones)

La Figura 4 presenta la ruta orientada a eventos: los servicios de negocio publican hechos mediante el patrón Transactional Outbox en los tópicos de Kafka (`audit-events`, `usage-events`, `transfer-events`, `onboarding-events`, `core-cdc`); los consumen el Servicio de Auditoría (registro inmutable), el Servicio de Perfil Digital (clientes frecuentes) y el Servicio de Notificaciones (dos canales), además del SIEM corporativo. Este desacople garantiza que ninguna acción del cliente quede sin auditar ni sin notificar, aunque los consumidores estén temporalmente caídos (retención y replay en Kafka).

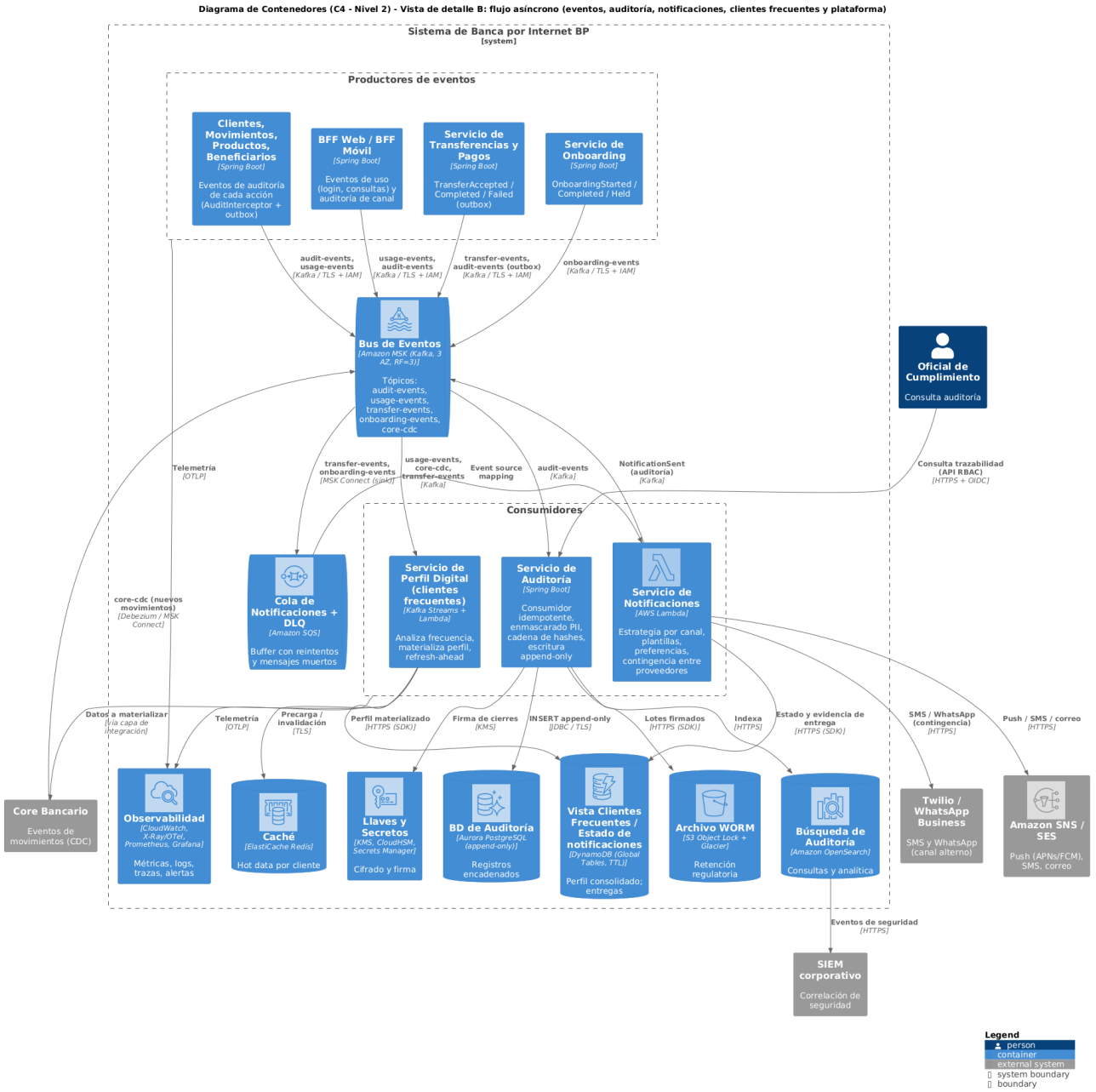


Figura 4. *Contenedores – vista de detalle B: flujo asíncrono de eventos hacia auditoría, perfil digital, notificaciones y SIEM.*

6. Vista de componentes (C4 – Nivel 3)

El nivel de componentes descompone los contenedores más significativos en sus unidades internas (controladores, servicios de dominio, puertos, adaptadores y repositorios) y muestra cómo colaboran y qué patrones aplican. Se documentan cinco vistas: (1) Servicio de Transferencias y Pagos con la capa de integración; (2) autenticación y autorización; (3) Onboarding facial; (4) auditoría; y (5) persistencia para clientes frecuentes. Todos los microservicios siguen una **arquitectura hexagonal (puertos y adaptadores)**: el dominio no depende de frameworks ni de sistemas externos, lo que facilita las pruebas y el reemplazo de proveedores.

6.1 Servicio de Transferencias y Pagos + capa de integración

Este servicio implementa el caso de uso más crítico: una transferencia es una transacción distribuida entre el Core (débito), la red interbancaria (crédito en otra entidad) y la propia base de datos del servicio. Dado que no es posible usar una transacción ACID que abarque a sistemas externos, se aplica el patrón **Saga orquestada** con acciones de compensación, combinado con **Idempotent Receiver** (para que reintentos del canal no dupliquen operaciones) y **Transactional Outbox** (para que los eventos de auditoría y notificación se publiquen exactamente una vez, en la misma transacción que el cambio de estado).

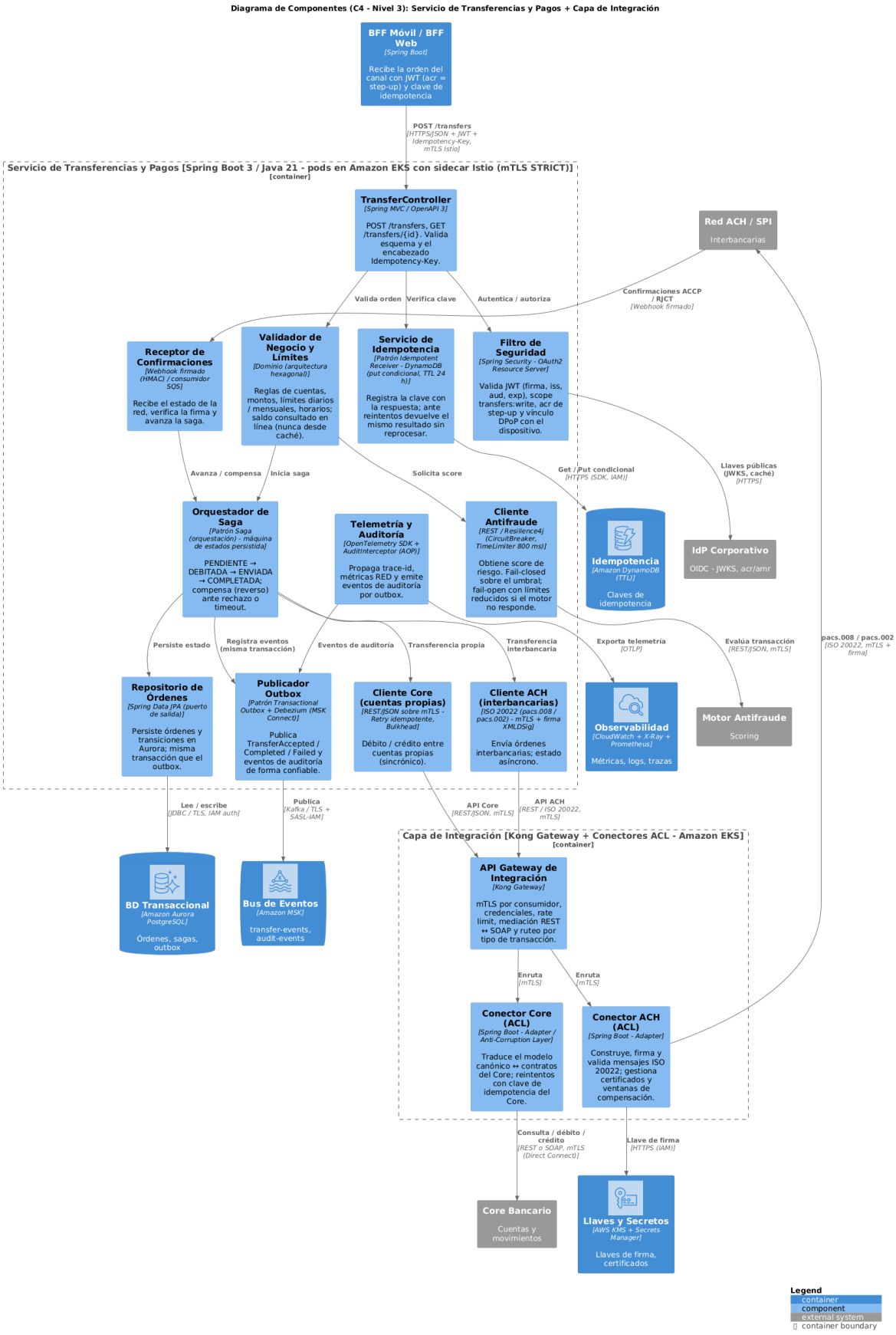


Figura 5. *Componentes (C4 – Nivel 3) del Servicio de Transferencias y Pagos y de la capa de integración.*

Componente	Patrón / tecnología	Responsabilidad
TransferController	Spring MVC, OpenAPI 3	Expone `POST /transfers` y `GET /transfers/{id}`; valida esquema, cabecera `Idempotency-Key` y trazabilidad.
Filtro de Seguridad	Spring Security – OAuth2 Resource Server	Revalida el JWT (firma, iss, aud, exp), exige `scope transfers:write`, el nivel de autenticación reforzada (`acr`) y la prueba DPoP ligada al dispositivo.
Servicio de Idempotencia	Idempotent Receiver – DynamoDB (put condicional, TTL 24 h)	Registra la clave con la respuesta; los reintentos reciben la misma respuesta sin reprocesar (evita transferencias duplicadas por fallos de red).
Validador de Negocio y Límites	Dominio (hexagonal)	Reglas de cuentas, beneficiarios, montos, límites diarios / mensuales por canal, horarios y saldo consultado en línea.
Cliente Antifraude	REST + Resilience4j (CircuitBreaker, TimeLimiter 800 ms, Bulkhead)	Obtiene el puntaje de riesgo; *fail-closed* sobre el umbral de monto y *fail-open* con límites reducidos si el motor no responde (decisión de negocio parametrizable).
Orquestador de Saga	Saga (orquestación) – máquina de estados persistida	PENDIENTE → DEBITADA → ENVIADA → COMPLETADA; ante rechazo o timeout ejecuta la compensación (reverso del débito) y marca REVERSADA.
Repositorio de Órdenes + Publicador Outbox	Spring Data JPA + Transactional Outbox (Debezium / MSK Connect)	Persiste órdenes, transiciones y filas de outbox en una sola transacción; Debezium publica los eventos a Kafka con garantía al-menos-una-vez y deduplicación por `event-id`.
Cliente Core / Cliente ACH	Adapter (puertos de salida) – mTLS; ISO 20022 + XMLDSig	Débito / crédito en cuentas propias (sincrónico) y envío de órdenes interbancarias (asincrónico) a través de la capa de integración.
Receptor de Confirmaciones	Webhook firmado (HMAC) / consumidor SQS	Recibe pacs.002 (ACCP / RJCT), verifica firma y ventana temporal, y avanza la saga.
Telemetría y Auditoría	OpenTelemetry SDK + AuditInterceptor (AOP)	Propaga trace-id, emite métricas RED y genera un evento de auditoría por cada transición vía outbox.
API Gateway de Integración (Kong) + Conectores ACL	Kong Gateway; Adapter / Anti-Corruption Layer	mTLS por consumidor, ruteo por tipo de transacción (propia → Core; interbancaria → ACH), traducción entre el modelo canónico y los contratos legados, reintentos con la clave de idempotencia del Core y gestión de certificados.

Decisión D-06 · Consistencia transaccional: Saga orquestada + Transactional Outbox + Idempotent Receiver

Opciones evaluadas: (a) transacción distribuida 2PC / XA; (b) saga coreografiada por eventos; (c) saga orquestada con outbox.

1. **Imposibilidad práctica de 2PC:** ni el Core (legado) ni la red interbancaria participan en un coordinador XA; además, 2PC bloquea recursos y reduce disponibilidad (teorema CAP: se prioriza disponibilidad con consistencia eventual acotada y compensaciones explícitas).
2. **Visibilidad y control del estado:** la orquestación centraliza la máquina de estados de cada transferencia (trazabilidad exigida por auditoría y atención al cliente), mientras la coreografía distribuye la lógica y dificulta detectar sagas incompletas.
3. **Publicación confiable de eventos:** el outbox elimina la "doble escritura" (base de datos y broker), garantizando que cada notificación y registro de auditoría corresponda a una transición realmente confirmada; la idempotencia en el receptor evita duplicados ante reintentos del canal o del gateway.

6.2 Autenticación y autorización (App Móvil, Web SPA e IdP)

La Figura 6 muestra los componentes que participan en la autenticación y autorización: en el dispositivo móvil (módulo AppAuth, módulo biométrico / passkeys, almacenamiento seguro por hardware, atestación y cliente HTTP con pinning y DPoP); en el canal web (SPA sin tokens y BFF con patrón Token Handler); en el borde (JWT Authorizer del API Gateway) y en el IdP corporativo configurado con perfil FAPI 2.0 (endpoints de autorización con PAR, token con DPoP, motor MFA / step-up, directorio de credenciales, JWKS y SCIM). El detalle de los flujos, los diagramas de secuencia y la comparación de flujos OAuth 2.0 se desarrollan en la sección 8.

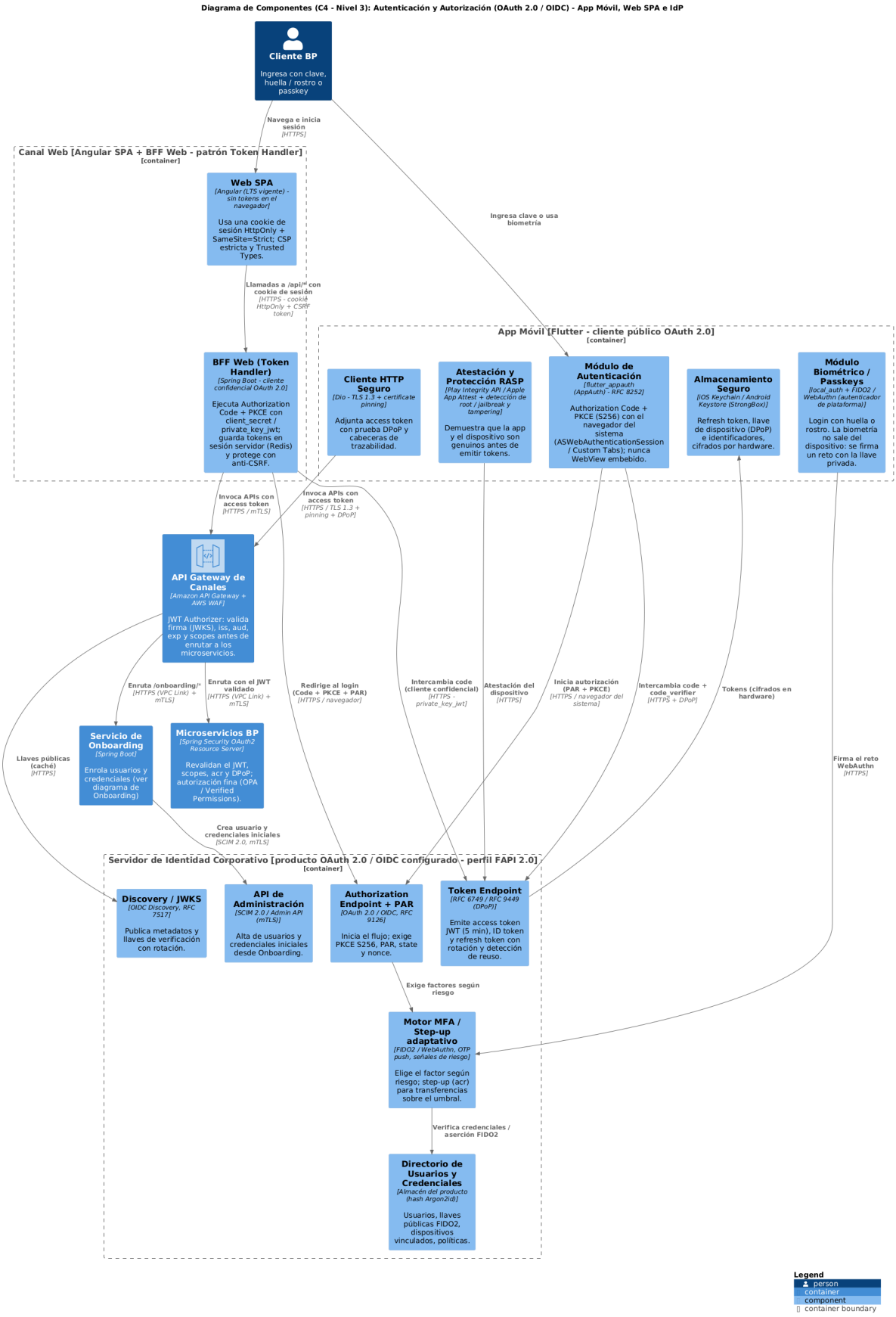


Figura 6. *Componentes (C4 – Nivel 3) de autenticación y autorización: App Móvil, canal Web, API Gateway e IdP corporativo.*

Componente	Estándar / tecnología	Función en el flujo
Módulo de Autenticación (móvil)	AppAuth (flutter_appauth) – RFC 8252, PKCE S256, PAR	Inicia Authorization Code + PKCE en el navegador del sistema (nunca WebView), recibe el code por App Link / Universal Link y lo intercambia con prueba DPoP.
Módulo Biométrico / Passkeys	FIDO2 / WebAuthn, local_auth	Login con huella o rostro: la biometría desbloquea una llave privada en hardware que firma el reto del IdP; la plantilla biométrica nunca sale del dispositivo.
Almacenamiento Seguro	iOS Keychain / Android Keystore (StrongBox)	Custodia refresh token y llave DPoP; access token solo en memoria.
Atestación y RASP	Play Integrity / App Attest, detección de root / jailbreak, anti-tampering	Demuestra que app y dispositivo son genuinos antes de emitir tokens; bloquea entornos comprometidos.
Web SPA + BFF Web (Token Handler)	Cookie `__Host-session` HttpOnly / Secure / SameSite=Strict, CSRF double-submit, cliente confidencial con `private_key_jwt`	El BFF ejecuta el flujo OAuth como cliente confidencial, guarda los tokens en sesión servidor (Redis) y el navegador solo maneja una cookie opaca (§8).
API Gateway – JWT Authorizer	JWKS (OIDC Discovery)	Valida firma, emisor, audiencia, expiración y scopes antes de enrutar; microservicios revalidan y verifican DPoP y `acr`.
IdP: Authorization Endpoint + PAR, Token Endpoint (DPoP), MFA / Step-up, Directorio, JWKS, SCIM	OAuth 2.0 / OIDC, RFC 9126, RFC 9449, FIDO2, Argon2id, SCIM 2.0	Emite tokens de corta vida con rotación de refresh tokens y detección de reuso; elige factores según riesgo; expone alta de usuarios para Onboarding.

6.3 Onboarding digital con reconocimiento facial

El Servicio de Onboarding es un **orquestador de proceso (Process Manager / Saga)** con una máquina de estados persistida que coordina, en orden, el consentimiento informado (LOPDP), la extracción del documento (Amazon Textract), la validación de identidad (Registro Civil), la prueba de vida y comparación facial (Amazon Rekognition tras un adaptador intercambiable), el screening AML / PEP, el alta del cliente en el Core y el CRM (a través de la capa de integración) y el enrolamiento de credenciales en el IdP (SCIM 2.0 + registro FIDO2). Las evidencias se guardan cifradas y con retención inmutable. La sección 9 detalla la evaluación de herramientas, el diagrama de secuencia y los controles.

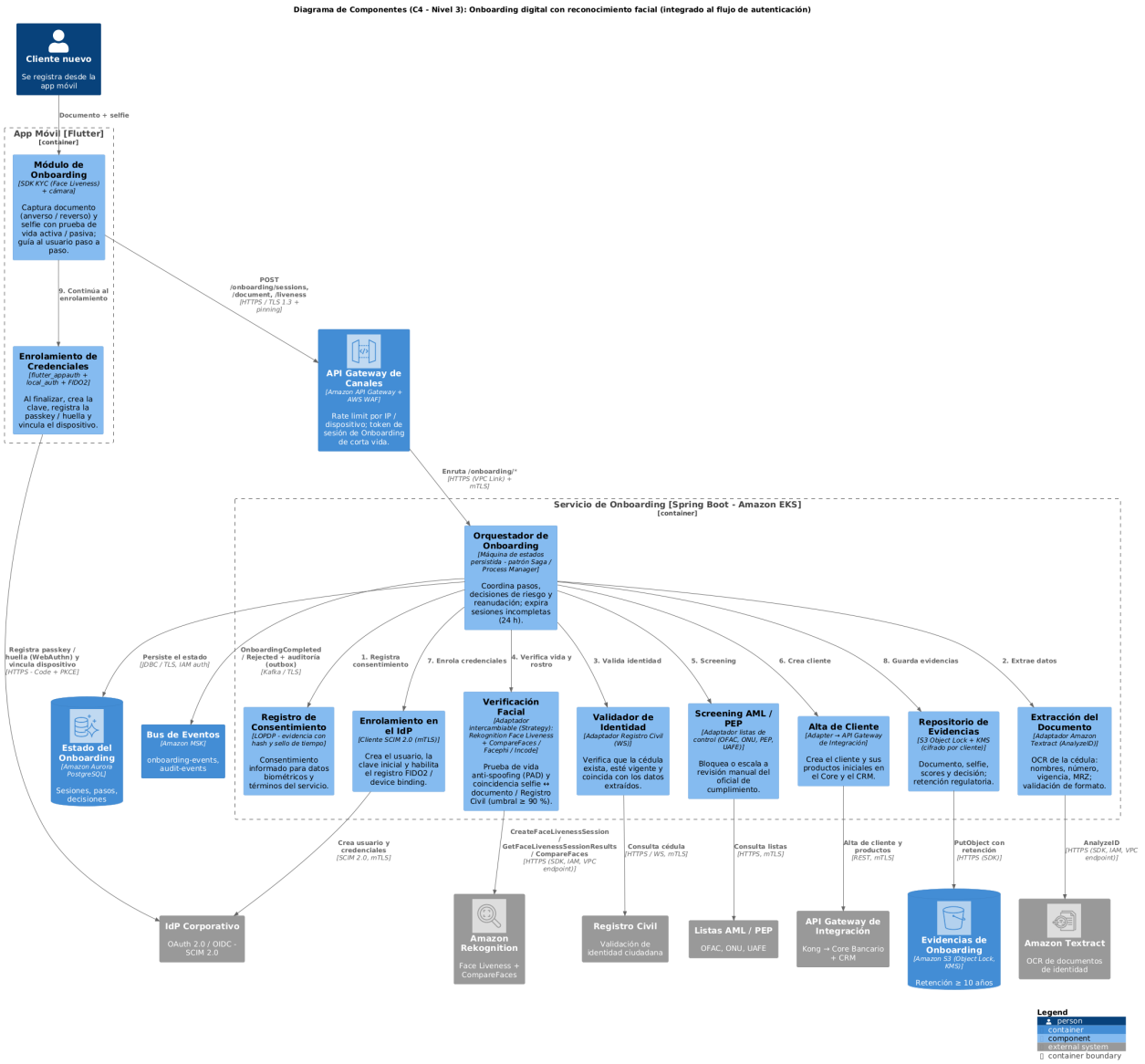


Figura 7. *Componentes (C4 – Nivel 3) del Onboarding digital con reconocimiento facial.*

6.4 Solución de auditoría de acciones del cliente

La auditoría debe registrar **todas** las acciones del cliente (inicio de sesión, consultas, transferencias, cambios de beneficiarios, preferencias, Onboarding), sin afectar la latencia de las operaciones y con garantías de integridad frente a manipulación, incluso por administradores. La Figura 8 muestra la solución completa: captura transversal en las fuentes, transporte durable, procesamiento en un servicio aislado en una cuenta AWS separada y almacenamiento en tres capas (relacional append-only, WORM y búsqueda).

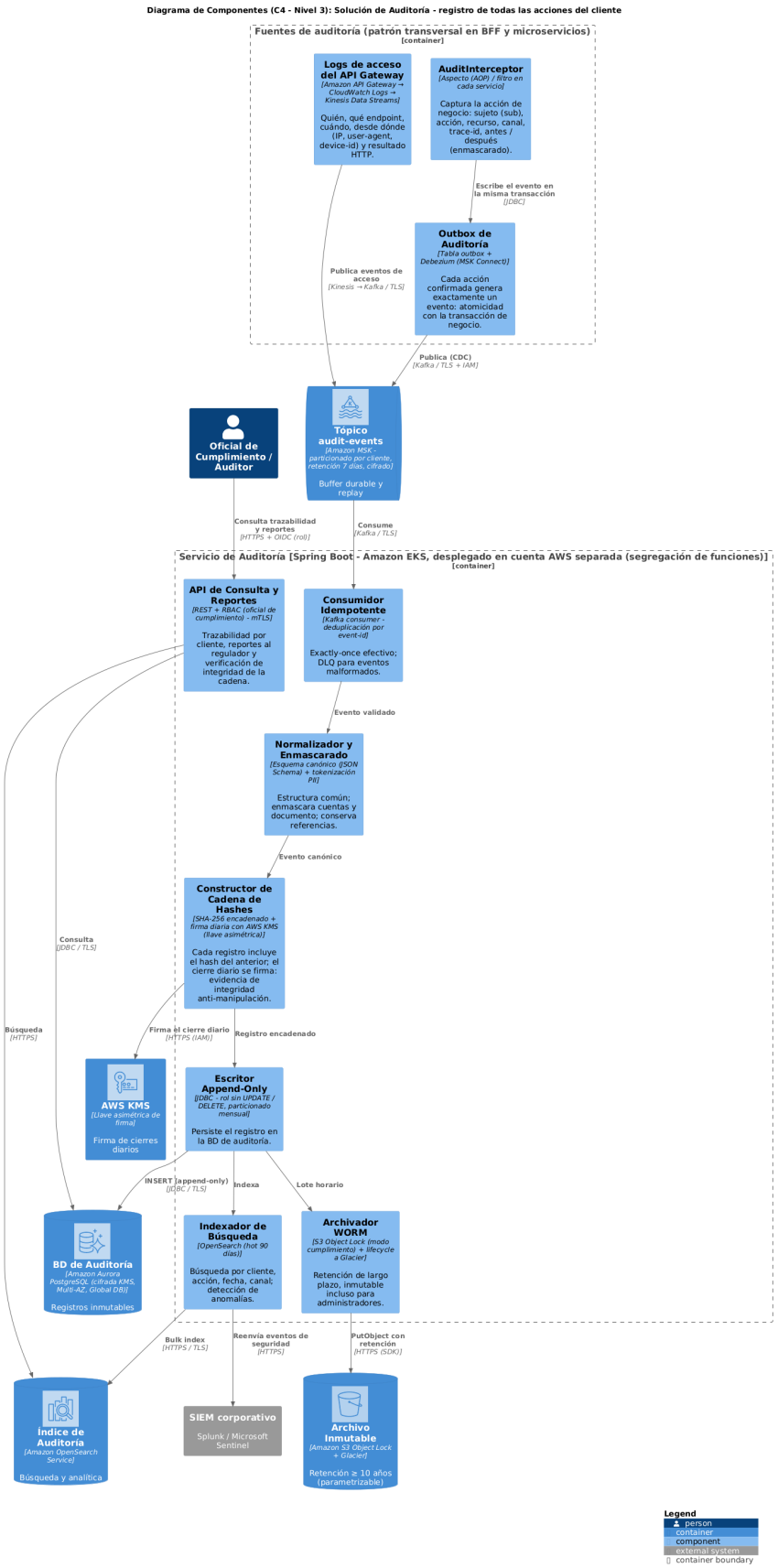


Figura 8. *Componentes (C4 – Nivel 3) de la solución de auditoría: fuentes, tópico durable, servicio de auditoría en cuenta separada y almacenamiento inmutable.*

6.4.1 Fuentes y captura (patrón transversal)

- **AuditInterceptor (AOP)** en BFF y microservicios: intercepta cada operación de negocio confirmada y produce un evento de auditoría en la **misma transacción** de base de datos (tabla outbox). Así, no puede existir una acción confirmada sin su evento ni un evento sin acción (atomicidad).
- **Logs de acceso del API Gateway** (CloudWatch Logs → Kinesis Data Streams → Kafka): quién, qué endpoint, cuándo, desde qué IP / dispositivo y con qué resultado HTTP, incluidas peticiones rechazadas por autorización o cuota (intentos fallidos también se auditan).
- **Eventos del IdP** (inicios de sesión, MFA, cambios de credenciales) reenviados por webhook / log streaming al mismo tópico.

6.4.2 Modelo de datos del registro de auditoría

Campo	Descripción	Campo	Descripción
`event_id`	UUID v7 (ordenable en el tiempo), clave de deduplicación.	`trace_id`	Correlación con logs y trazas (OpenTelemetry).
`timestamp_utc`	Instante del hecho con precisión de ms (reloj sincronizado NTP).	`subject`	Identificador del cliente (`sub` del token), nunca el número de cédula en claro.
`action`	Catálogo: LOGIN, LOGIN_FAILED, QUERY_MOVEMENTS, TRANSFER_INITIATED, TRANSFER_COMPLETED, BENEFICIARY_ADDED, ONBOARDING_STEP, PREFERENCE_CHANGED, LOGOUT…	`resource`	Recurso afectado (cuenta enmascarada, id de orden, beneficiario).
`channel` / `client_app`	WEB / MOBILE, versión de la app.	`device_id`, `ip`, `geo`, `user_agent`	Contexto del dispositivo (device binding), IP de origen y geolocalización aproximada.
`acr` / `amr`	Nivel y métodos de autenticación usados (p. ej. aal3, fido).	`result`	SUCCESS / DENIED / ERROR con código.
`before` / `after`	Estado previo y posterior para cambios (enmascarado y tokenizado).	`prev_hash`, `hash`	SHA-256 del registro anterior y del actual (cadena de integridad).
`service`, `version`	Servicio emisor y versión desplegada.	Firma diaria	Cierre diario firmado con llave asimétrica en AWS KMS (no exportable).

6.4.3 Procesamiento y almacenamiento

- **Consumidor idempotente** (Kafka, deduplicación por `event_id`, DLQ para eventos malformados) → **Normalizador y enmascarado** (esquema canónico JSON Schema; tokenización de cuentas y documentos, sin datos biométricos) → **Constructor de cadena de hashes** (cada registro incorpora el hash del anterior; cierre diario firmado con KMS; verificación periódica y bajo demanda por el auditor).
- **Escritor append-only** sobre Aurora PostgreSQL: el rol de la aplicación solo tiene `INSERT`; no existen permisos de `UPDATE` / `DELETE`; particionamiento mensual; cifrado con KMS; Aurora Global Database para DR.
- **Archivador WORM**: lotes horarios a S3 con Object Lock en modo *compliance* (ni siquiera la cuenta raíz puede borrar antes del plazo) y lifecycle a S3 Glacier Deep Archive; retención parametrizable (por defecto 10 años, alineada con los plazos de conservación de la normativa financiera).
- **Indexador** hacia OpenSearch (90 días en caliente) para búsqueda por cliente, acción, fecha y canal, y detección de anomalías; reenvío al SIEM corporativo.
- **API de consulta y reportes** con RBAC (oficial de cumplimiento, auditor) y autenticación OIDC, que registra a su vez cada consulta (auditoría de la auditoría).

Decisión D-10 · Auditoría orientada a eventos, en cuenta separada, con cadena de hashes firmada y WORM (frente a triggers en la BD, logs de aplicación o un ledger propietario)

1. **Completitud y atomicidad:** el interceptor + outbox garantiza que toda acción confirmada produzca exactamente un evento (no depende de que cada desarrollador "recuerde" auditar) y los logs del gateway cubren incluso los intentos rechazados; los triggers de BD solo verían cambios de datos, no consultas ni intentos fallidos.
2. **Integridad verificable y segregación de funciones:** la cadena de hashes con cierre firmado (llave no exportable en KMS) hace detectable cualquier alteración; el servicio corre en una cuenta AWS distinta con políticas SCP que impiden a los administradores de producción modificar o borrar registros; S3 Object Lock en modo compliance añade inmutabilidad física.
3. **Rendimiento y resiliencia:** la auditoría es asíncrona y no añade latencia a la ruta transaccional; Kafka conserva los eventos si el servicio de auditoría está caído. Se descartó Amazon QLDB (anunciada su discontinuación) y una blockchain privada (costo y complejidad sin beneficio adicional frente a un ledger centralizado firmado).

6.5 Persistencia de información para clientes frecuentes

El enunciado solicita un mecanismo de persistencia para clientes frecuentes basado en patrones de diseño, relacionando los componentes involucrados. La solución (Figura 9) parte de un principio: **el Core y el CRM siguen siendo la fuente de verdad**; para los clientes con uso recurrente se mantiene una **vista materializada** de su información (datos básicos, productos, últimos 50 movimientos) que se sirve desde caché y se actualiza por eventos, de modo que la experiencia sea instantánea y la carga sobre el Core disminuya en las horas pico.

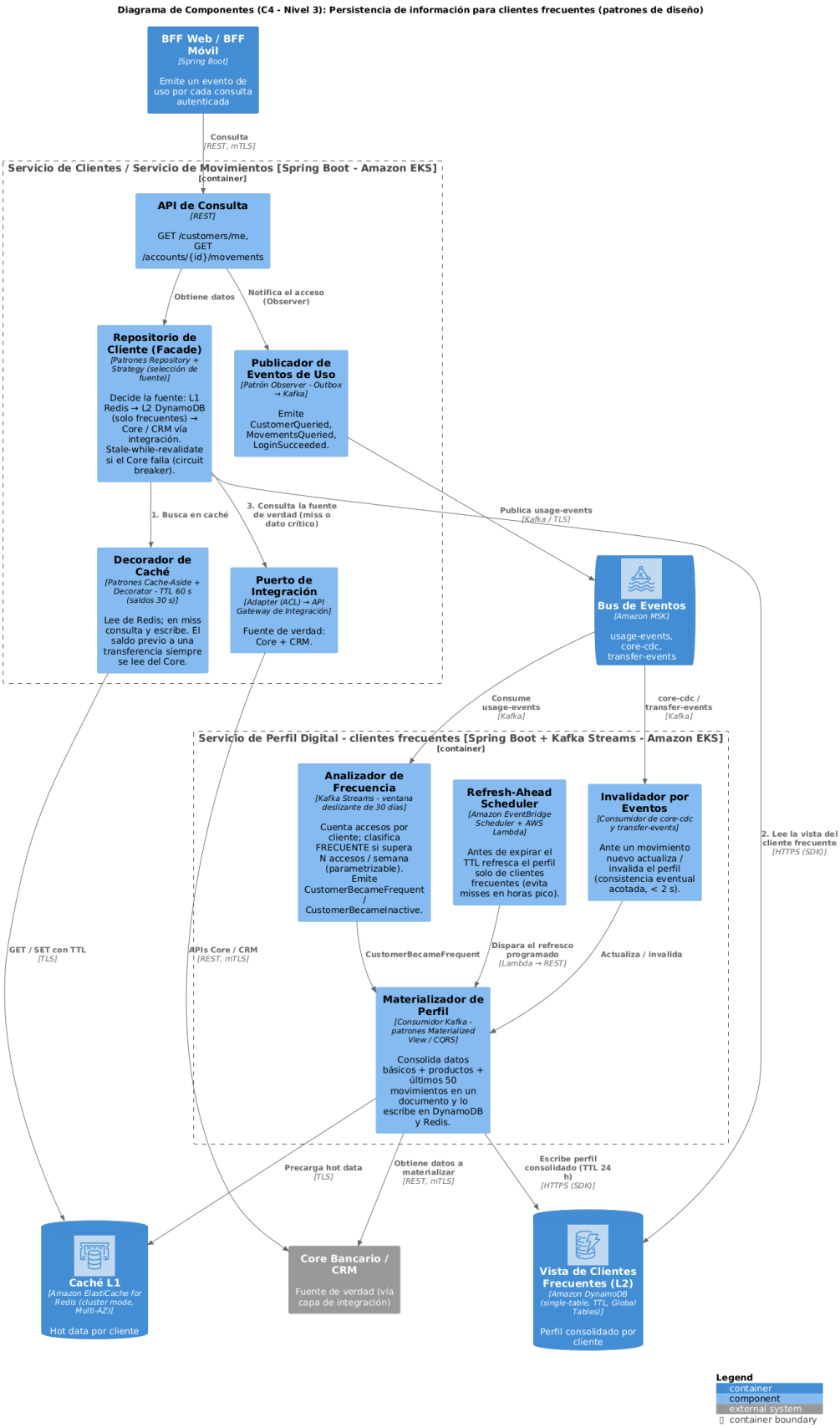


Figura 9. *Componentes (C4 – Nivel 3) del mecanismo de persistencia para clientes frecuentes y patrones de diseño aplicados.*

Patrón	Componente(s)	Cómo se aplica y relación con los demás componentes
Repository + Strategy	Repositorio de Cliente (fachada) en los servicios de Clientes y Movimientos	El repositorio oculta la fuente de datos al dominio y elige una estrategia de lectura: L1 Redis → L2 DynamoDB (solo si el cliente es frecuente) → Core / CRM vía capa de integración. Si el Core falla, aplica *stale-while-revalidate* con datos recientes marcados como tales.
Cache-Aside + Decorator	Decorador de Caché sobre el repositorio	Envuelve al repositorio: lee de Redis; en un miss consulta la fuente y escribe con TTL (60 s datos básicos, 30 s saldos). El saldo previo a una transferencia siempre se lee del Core (consistencia fuerte donde importa).
Observer (eventos de uso)	Publicador de Eventos de Uso → tópico `usage-events`	Cada consulta autenticada emite un evento (CustomerQueried, MovementsQueried, LoginSucceeded) por outbox; los observadores (Analizador de Frecuencia, auditoría) reaccionan sin acoplar el flujo de consulta.
Sliding Window / Stream Processing	Analizador de Frecuencia (Kafka Streams)	Ventana deslizante de 30 días por cliente; clasifica FRECUENTE si supera N accesos por semana (parámetro) y emite CustomerBecameFrequent / CustomerBecameInactive.
Materialized View / CQRS	Materializador de Perfil → DynamoDB (L2) y Redis (L1)	Construye un documento consolidado por cliente (single-table, TTL 24 h, Global Tables) optimizado para lectura; separa el modelo de lectura del transaccional del Core.
Refresh-Ahead	Refresh-Ahead Scheduler (EventBridge Scheduler + Lambda)	Refresca proactivamente el perfil de los clientes frecuentes antes de que expire el TTL, evitando misses en horas pico (p. ej. antes de las 7:00 y de las 12:00).
Event-driven invalidation	Invalidador por Eventos (consume `core-cdc` y `transfer-events`)	Ante un movimiento nuevo actualiza o invalida el perfil en menos de 2 s (consistencia eventual acotada), sin esperar al TTL.
Circuit Breaker / Fallback	Puerto de Integración (Resilience4j)	Si el Core está degradado, los clientes frecuentes siguen viendo sus datos recientes con indicación de hora de actualización; los no frecuentes reciben un mensaje de degradación controlada.

Decisión D-11 · Vista materializada por eventos (DynamoDB + Redis) frente a solo caché TTL o réplica completa del Core

1. **Rendimiento con consistencia acotada:** una caché TTL simple obliga a elegir entre datos viejos o misses frecuentes; la vista actualizada por eventos (CDC y transferencias) ofrece lecturas en milisegundos y actualización casi inmediata tras cada movimiento, manteniendo la lectura fuerte donde es obligatoria (saldo pre-transacción).
2. **Reducción de carga y costo en el Core:** los clientes frecuentes concentran la mayoría de las consultas (Pareto); servirlos desde DynamoDB / Redis reduce llamadas al legado y protege su capacidad para transacciones.
3. **Alcance limitado por diseño:** replicar todo el Core sería costoso, difícil de mantener consistente y expondría más datos personales; la vista solo contiene lo necesario, con TTL y cifrado (minimización de datos, LOPDP).

6.6 Servicios de consulta y notificaciones

Servicios de consulta (Clientes, Productos y Saldos, Movimientos). Comparten la misma estructura hexagonal: un controlador REST, un servicio de aplicación con autorización fina (el cliente solo accede a sus productos: verificación `sub` = titular, políticas en Cedar / OPA), el repositorio con las estrategias de lectura de la sección 6.5, el puerto de integración hacia Kong (Core y CRM) y el AuditInterceptor. Exponen contratos OpenAPI versionados reutilizables desde ambos BFF.

Servicio de Notificaciones. Implementado en AWS Lambda con Amazon SQS (colas por canal y DLQ), consume los eventos de negocio y de seguridad, resuelve las preferencias del cliente, renderiza plantillas versionadas y despacha por al menos dos canales aplicando los patrones **Strategy** (un adaptador por canal y proveedor), **Chain of Responsibility** (contingencia: push → SMS → correo, o WhatsApp → SMS) e **Idempotent Receiver** (deduplicación por `event_id`). Los acuses de entrega se registran como evidencia y evento de auditoría (detalle en la sección 11).

7. Arquitectura de front-end: Web SPA y App Móvil

7.1 Canal web: Single Page Application

La banca web se construye como una SPA servida como contenido estático desde Amazon S3 a través de CloudFront (con AWS WAF y Shield Advanced), que consume exclusivamente al BFF Web. La aplicación se estructura por funcionalidades (módulos *lazy-loaded*: inicio, movimientos, transferencias, beneficiarios, perfil) sobre un **design system** compartido con la app móvil (tokens de diseño, componentes accesibles WCAG 2.2 AA) y un estado gestionado con *signals* / store. Los controles de seguridad del canal web son los siguientes:

- **Sin tokens en el navegador:** patrón Token Handler (BFF): cookie `__Host-session` HttpOnly, Secure, SameSite=Strict y protección CSRF por doble envío + verificación de `Origin`; elimina el robo de tokens por XSS.
- **Content Security Policy estricta** con nonces, `Trusted Types`, `Subresource Integrity` en los assets, HSTS con preload, cabeceras `X-Frame-Options / frame-ancestors`, `Referrer-Policy` y `Permissions-Policy`.
- **Sesión:** expiración por inactividad (5 min) y absoluta (30 min), cierre de sesión con revocación de tokens, detección de múltiples sesiones y cierre remoto.
- **Huella del navegador y señales de riesgo** (no identificatorias) enviadas al motor antifraude; captcha adaptativo en el login.
- **Enmascaramiento en pantalla** de números de cuenta y datos sensibles; sin datos en `localStorage`; autoborrado de formularios.
- **Calidad:** pruebas unitarias y e2e, análisis SAST / SCA en el pipeline, monitoreo RUM (Core Web Vitals, errores JS).

Decisión D-07 · Framework de la SPA: Angular (frente a React y Vue)

Criterio	Angular	React (+ ecosistema)	Vue
Modelo	Framework completo y opinado: enrutador, formularios reactivos, HTTP, i18n, DI, pruebas integradas.	Biblioteca de UI; enrutador, estado, formularios y HTTP se seleccionan y mantienen por separado.	Framework progresivo; ecosistema oficial más pequeño que Angular.
Seguridad integrada	Sanitización automática por contexto, soporte de CSP con nonces y Trusted Types, guía oficial de seguridad.	Escapa por defecto, pero `dangerouslySetInnerHTML` y bibliotecas de terceros amplían la superficie.	Escapa por defecto; menos herramientas de gobierno a escala.
Gobernanza a escala bancaria	Convenciones únicas, TypeScript obligatorio, ciclo LTS predecible (versión mayor cada 6 meses, soporte 18 meses), tooling de migración automática.	Máxima flexibilidad → mayor esfuerzo de estandarización entre equipos; cambios de paradigma frecuentes en el ecosistema.	Comunidad empresarial menor en la región.
Rendimiento	Comparable (signals, hidratación, compilación AOT).	Excelente; ecosistema de meta-frameworks.	Excelente.

Selección: Angular. Justificaciones: (1) reduce el riesgo de seguridad y de inconsistencia con un stack opinado, tipado y con controles de seguridad de serie, adecuados para un canal financiero; (2) su ciclo de soporte y herramientas de migración facilitan el mantenimiento de largo plazo por varios equipos; (3) formularios reactivos y validaciones sincronizadas con OpenAPI reducen defectos en flujos transaccionales. React se mantiene como alternativa válida si BP ya cuenta con equipos especializados; en ese caso se adoptaría con un meta-framework y lineamientos de seguridad equivalentes.

7.2 Canal móvil: aplicación multiplataforma

La app móvil se desarrolla con un solo código base para iOS y Android, siguiendo **Clean Architecture** (capas de presentación, dominio y datos) con gestión de estado BLoC / Riverpod, y cumple OWASP MASVS-L2 con protección de resiliencia (MASVS-R). Controles de seguridad del canal móvil:

- **Autenticación:** AppAuth (Authorization Code + PKCE, RFC 8252) con el navegador del sistema; nunca WebView embebido; tokens DPoP; refresh token en Keychain / Keystore (StrongBox / Secure Enclave); access token solo en memoria.
- **Biometría / passkeys FIDO2:** huella o rostro desbloquean una llave privada en hardware; la plantilla biométrica nunca sale del dispositivo ni se envía a BP.
- **Integridad:** atestación Play Integrity / App Attest, detección de root / jailbreak, hooking y depuración (RASP), ofuscación (R8 / ProGuard, obfuscación de Dart), verificación de firma de la app, bloqueo de capturas de pantalla en vistas sensibles.
- **Comunicaciones:** TLS 1.3 con certificate pinning (con plan de rotación) y cabeceras de trazabilidad; sin tráfico en claro.
- **Datos en el dispositivo:** mínimos, cifrados con llaves de hardware; borrado remoto de sesión; sin logs con PII.
- **Push:** Firebase Cloud Messaging / APNs a través de Amazon SNS, sin datos sensibles en el payload (solo referencia al evento).
- **Onboarding:** SDK de prueba de vida (Amazon Rekognition Face Liveness), captura guiada de documento, atestación previa, límites de intentos.

Decisión D-08 · Framework móvil multiplataforma: Flutter (frente a React Native; nativo y Kotlin Multiplatform evaluados)

Criterio	Flutter (Dart)	React Native (JavaScript / TypeScript)	Nativo (Swift / Kotlin) y KMP
Rendimiento y UI	Compilación AOT a código nativo ARM; motor de render propio (Impeller) → UI idéntica en iOS y Android, 60–120 fps.	Motor Hermes + nueva arquitectura (JSI); UI con componentes nativos (puede diferir entre plataformas).	Máximo rendimiento y acceso a APIs; dos bases de código (o lógica compartida con KMP).
Seguridad	Código compilado (más difícil de revertir que un bundle JS), plugins maduros: flutter_appauth, local_auth, flutter_secure_storage, dio con pinning, freerasp.	Bundle JS más fácil de inspeccionar; requiere ofuscación adicional; buen ecosistema de librerías de seguridad.	Mejor integración con Keychain / Keystore y atestación; mayor costo de mantener dos equipos.
Productividad y costo	Un equipo, un código; hot reload; design system compartido con la web (tokens).	Un equipo; reutiliza conocimiento de React del equipo web.	Dos equipos y dos ciclos de release; mayor costo (~1,7×).
Ecosistema bancario	Ampliamente adoptado por bancos y fintech en LatAm; respaldo de Google.	Respaldo de Meta; adopción amplia.	Estándar histórico.

Selección: Flutter. Justificaciones: (1) rendimiento y consistencia visual con un único código compilado, lo que reduce defectos específicos de plataforma en flujos críticos (Onboarding con cámara, biometría); (2) el código AOT y el ecosistema de plugins de seguridad facilitan cumplir MASVS-R; (3) menor costo total y un solo ciclo de despliegue. React Native es la alternativa razonable si BP prioriza reutilizar equipos React de la web; el desarrollo nativo se descartó por costo y tiempo, manteniendo módulos nativos solo donde sea imprescindible (p. ej. SDKs biométricos) mediante *platform channels*.

8. Autenticación y autorización con OAuth 2.0 / OpenID Connect

8.1 El IdP existente como Authorization Server

El producto de identidad de BP se configura como **Authorization Server OAuth 2.0 y OpenID Provider** con un *realm* para clientes de banca digital. Se registran tres clientes: **bp-mobile** (cliente público, redirect URIs reclamadas por App Links / Universal Links, PKCE obligatorio, DPoP), **bp-web-bff** (cliente confidencial autenticado con `private_key_jwt`) y **bp-onboarding** (cliente confidencial con acceso SCIM). Se habilita el perfil de seguridad **FAPI 2.0** (PAR obligatorio, PKCE S256, tokens ligados al emisor / al dispositivo, sin *implicit* ni *password grant*), OIDC Discovery / JWKS con rotación de llaves y las políticas de token de la Tabla 8.2.

8.2 Comparación de flujos y recomendación

Flujo OAuth 2.0	Uso previsto por el estándar	Evaluación para BP	Decisión
Authorization Code + PKCE	Aplicaciones nativas, SPA y web con backend; recomendado por OAuth 2.0 Security BCP (RFC 9700), OAuth for Native Apps (RFC 8252) y OAuth 2.1.	El código de autorización viaja por redirección pero solo puede canjearse con el `code_verifier` que posee el cliente original; protege contra intercepción y ataques de mezcla. Compatible con MFA, step-up, PAR, DPoP y FAPI 2.0.	**Recomendado** (móvil: cliente público; web: vía BFF cliente confidencial)
Authorization Code (sin PKCE) con secreto	Aplicaciones web clásicas con backend.	Válido solo con cliente confidencial; se usa en el BFF pero siempre con PKCE adicional (FAPI 2.0 lo exige).	Solo en BFF, con PKCE
Implicit	SPA sin backend (histórico).	Expone el access token en la URL / historial, sin autenticación del cliente ni refresh seguro; **desaconsejado** por RFC 9700 y eliminado en OAuth 2.1.	Descartado
Resource Owner Password Credentials (ROPC)	Migraciones legadas.	La app manejaría la clave del usuario, impide MFA / passkeys y phishing-resistencia; **prohibido** por RFC 9700.	Descartado
Client Credentials	Máquina a máquina.	Se usa para llamadas servicio a servicio (Onboarding → SCIM, conectores → Core) con mTLS y tokens de corta vida.	Solo M2M
Device Authorization Grant	Dispositivos sin navegador.	No aplica (los canales tienen navegador).	No aplica
Hybrid (OIDC)	Casos mixtos.	Añade complejidad sin beneficio frente a Code + PKCE con PAR.	Descartado

Decisión D-09 · Flujo Authorization Code + PKCE (perfil FAPI 2.0 con PAR y DPoP); SPA a través de BFF (Token Handler); móvil como cliente público con AppAuth

1. **Alineación con el estándar vigente:** RFC 9700 (OAuth 2.0 Security Best Current Practice), RFC 8252 (Native Apps) y el borrador OAuth 2.1 convergen en Authorization Code + PKCE como el único flujo interactivo recomendado; Implicit y ROPC están desaconsejados / prohibidos por exponer tokens o credenciales.
2. **Protección del token según el tipo de cliente:** en el navegador, cualquier token es vulnerable a XSS; el patrón BFF / Token Handler (IETF *OAuth 2.0 for Browser-Based Apps*) mantiene los tokens en el servidor y entrega al navegador solo una cookie HttpOnly. En el móvil, AppAuth con navegador del sistema evita que la app vea la clave del usuario y permite reutilizar sesiones y passkeys; DPoP (RFC 9449) liga el token al dispositivo, de modo que un token robado no sirve en otro equipo.
3. **Exigencias del sector financiero:** FAPI 2.0 (usado en open banking) añade PAR (RFC 9126) para que los parámetros de autorización no viajen por el front-channel, tokens *sender-constrained*, y elimina prácticas débiles; esto anticipa requisitos regulatorios de open finance y refuerza la seguridad de transacciones.

Política de tokens y sesiones

Elemento	Política
Access token	JWT firmado (ES256), vida 5 minutos, `aud` = API Gateway de canales, `scope` mínimos por funcionalidad (accounts:read, movements:read, transfers:write, beneficiaries:write, profile:write), `cnf.jkt` (DPoP) en móvil; claims `acr` / `amr`.
Refresh token	Opaco, rotativo en cada uso, vida 30 días (móvil) / 8 h (BFF), detección de reuso con revocación de la familia completa, ligado al dispositivo (DPoP) y revocable desde la app (cierre remoto).
ID token	OIDC, con `nonce`, usado por el cliente solo para identidad de sesión; nunca como credencial de API.
Autenticación reforzada (step-up)	Transferencias sobre un umbral, altas de beneficiarios y cambios de datos de contacto exigen `acr=aal3` (FIDO2 / biometría) obtenido en los últimos 2 minutos; el microservicio responde `403 insufficient_user_authentication` con `acr_values` para que la app reautorice (patrón step-up, RFC 9470). Equivale al concepto de *Strong Customer Authentication* con vinculación dinámica (monto y beneficiario incluidos en la firma de la transacción).
MFA	Obligatoria: passkey / biometría FIDO2 (resistente a phishing, NIST 800-63B AAL3 con autenticador de hardware) o clave + OTP push con verificación de número; sin SMS OTP como factor primario (susceptible a SIM-swap), permitido solo como respaldo con límites reducidos.
Autorización fina	Modelo ABAC / ReBAC: el cliente solo opera sobre productos de los que es titular o apoderado; políticas centralizadas en Amazon Verified Permissions (Cedar) o Open Policy Agent, evaluadas en cada microservicio; los scopes del token limitan qué APIs puede invocar el canal.
Gestión de dispositivos	Enrolamiento con atestación; máximo N dispositivos activos; notificación de inicio de sesión en dispositivo nuevo por dos canales; revocación desde la app o el contact center.

8.3 Flujos de autenticación (diagramas de secuencia)

App Móvil (Figura 10). El inicio de sesión en el móvil comprende: generación de PKCE y llave DPoP, PAR, autorización en el navegador del sistema con dos variantes (usuario y clave + segundo factor, o passkey / biometría FIDO2), intercambio del código con atestación del dispositivo, emisión de tokens, consumo de APIs a través del API Gateway (validación en el borde y en el microservicio), renovación con rotación de refresh tokens y step-up para una transferencia sobre el umbral.

Web SPA mediante BFF (Figura 11). El patrón Token Handler garantiza que la SPA nunca reciba tokens: el BFF actúa como cliente confidencial ante el IdP, guarda los tokens en la sesión servidor (Redis) y expone al navegador una cookie de sesión endurecida; cada llamada a la API pasa por el BFF, que valida sesión, CSRF y origen, renueva tokens si es necesario e invoca al API Gateway. El cierre de sesión revoca tokens en el IdP (RFC 7009) y destruye la sesión.

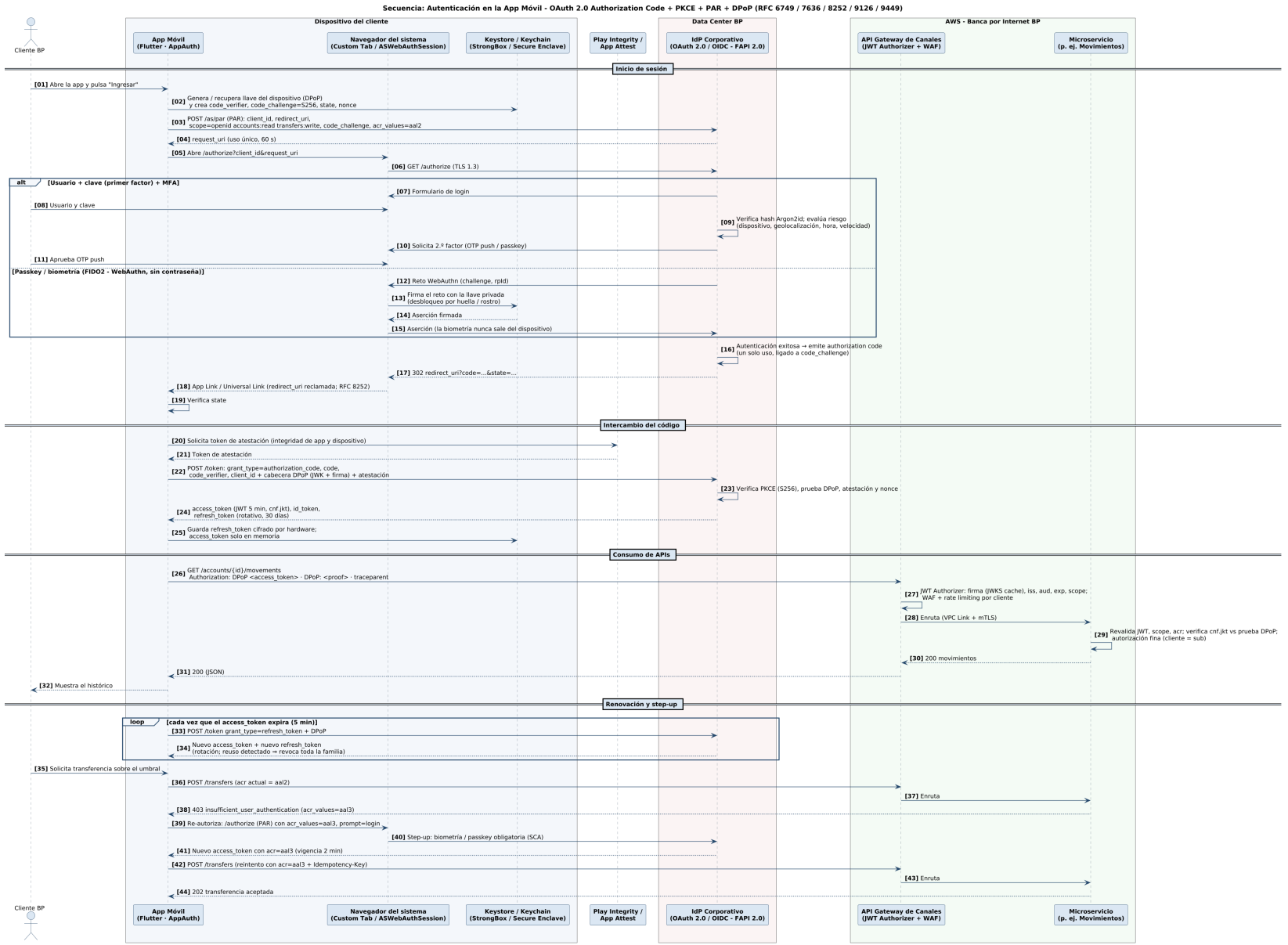


Figura 10. *Diagrama de secuencia: autenticación en la App Móvil con Authorization Code + PKCE + PAR + DPoP, MFA y step-up.*



Figura 11. *Diagrama de secuencia: autenticación de la Web SPA a través del BFF Web (patrón Token Handler).*

9. Onboarding digital con reconocimiento facial

9.1 Proceso y controles

El Onboarding permite a un ciudadano convertirse en cliente desde la app en menos de cinco minutos, con un nivel de aseguramiento de identidad equivalente a IAL2 (NIST 800-63A): evidencia documental verificada contra la fuente oficial, prueba de vida contra ataques de presentación (fotos, videos, máscaras, *deepfakes* por inyección) y comparación biométrica 1:1. Los pasos y controles son:

1. **Consentimiento informado (LOPDP):** antes de capturar datos biométricos se muestra y registra el consentimiento explícito con hash y sello de tiempo, indicando finalidad, base legal, plazo de conservación y derechos ARCO; el tratamiento de datos biométricos se considera de categoría especial.
2. **Captura y extracción del documento:** anverso y reverso de la cédula con guía en pantalla; Amazon Textract AnalyzeID extrae nombres, número, fechas y MRZ; se validan formato, dígito verificador y vigencia.
3. **Validación en Registro Civil:** los datos extraídos se contrastan con la fuente oficial (y su fotografía cuando el convenio lo permite).
4. **Prueba de vida y comparación facial:** Amazon Rekognition Face Liveness (sesión creada por el backend y ejecutada por el SDK de la app con reto activo) y CompareFaces entre la selfie de referencia y la foto del documento / Registro Civil; umbrales configurables (≥ 90 % por defecto), máximo tres intentos y luego revisión manual.
5. **Screening AML / PEP:** consulta de listas OFAC, ONU, PEP y UAFE; coincidencias derivan a revisión del oficial de cumplimiento (SLA 24 h) con evidencia completa.
6. **Alta del cliente:** creación idempotente en el Core (cliente y cuenta inicial) y en el CRM (perfil), a través del API Gateway de integración.
7. **Enrolamiento de credenciales:** creación del usuario en el IdP (SCIM 2.0), definición de clave con política de complejidad, registro de passkey / huella (FIDO2 / WebAuthn) y vinculación del dispositivo; primera sesión con Authorization Code + PKCE.
8. **Evidencias y auditoría:** documento, selfie, puntajes, decisiones y consentimiento se almacenan cifrados por cliente en S3 con Object Lock; cada paso emite eventos de auditoría; se notifica la apertura por dos canales.

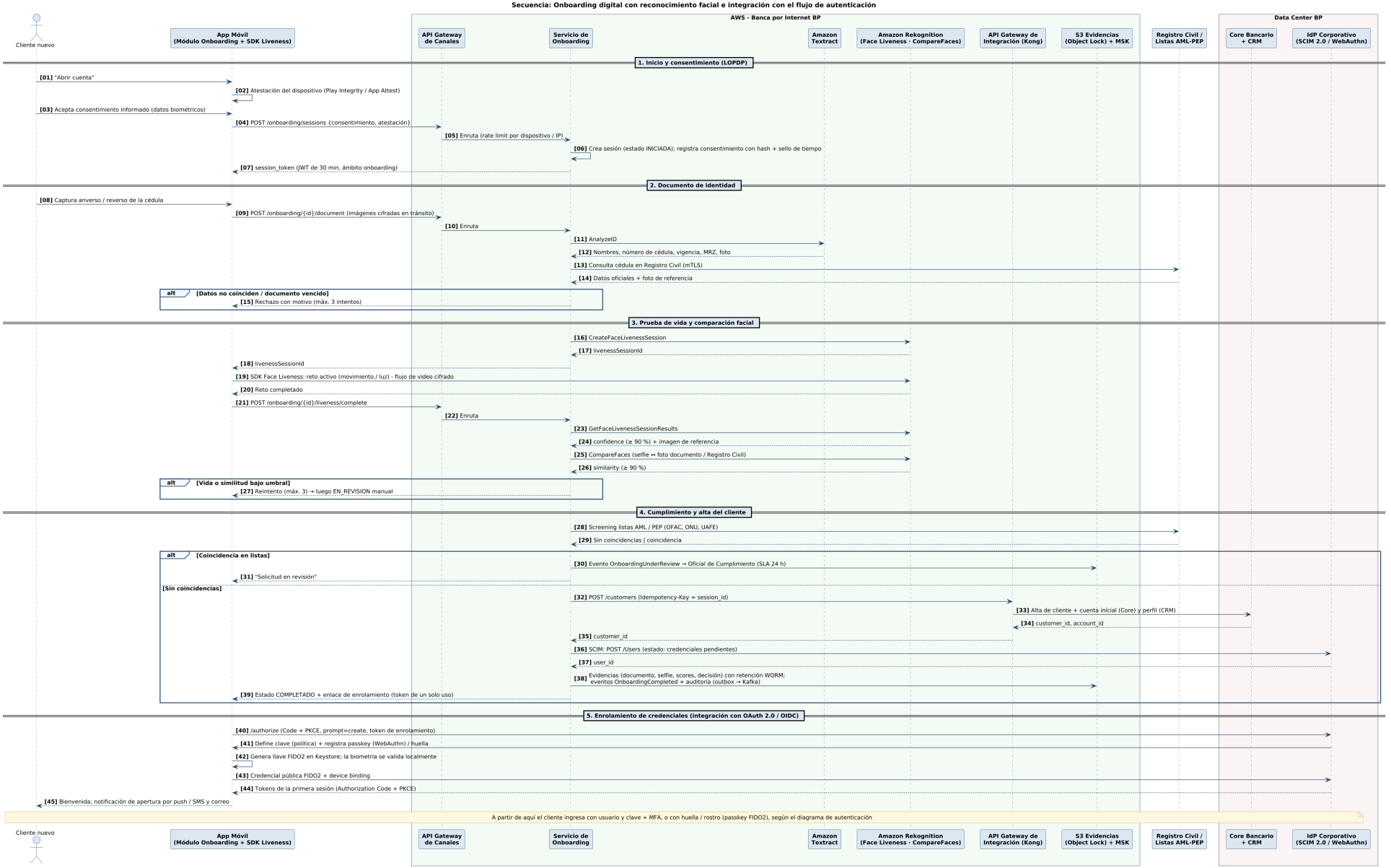


Figura 12. *Diagrama de secuencia del Onboarding digital con reconocimiento facial y su integración con el flujo de autenticación.*

9.2 Evaluación de herramientas de la industria

Herramienta	Capacidades relevantes	Consideraciones
Amazon Rekognition Face Liveness + CompareFaces + Amazon Textract AnalyzeID	Prueba de vida activa (reto en pantalla) con SDK para iOS / Android / web, comparación facial 1:1, OCR especializado en documentos de identidad; integración nativa con IAM, KMS, VPC endpoints y CloudTrail.	Pago por uso sin licencias mínimas; datos procesados en la misma región (us-east-1); servicio gestionado sin SDK propietario complejo. Requiere validar con Cumplimiento la evidencia de pruebas PAD del proveedor.
Facephi	Suite KYC ampliamente usada por bancos de Latinoamérica: liveness pasivo / activo con certificación ISO/IEC 30107-3 (iBeta), OCR y verificación de documentos regionales, firma electrónica.	Licenciamiento por transacción / suscripción; SDK nativo; soporte local. Alternativa preferente si BP exige certificación PAD explícita o soporte regional dedicado.
Incode	Plataforma de identidad con liveness pasivo certificado, verificación de documentos y comparación contra fuentes gubernamentales en varios países.	SaaS; buena cobertura latinoamericana; costo por verificación.
Jumio / Onfido (Entrust) / Veriff	Verificación global de identidad con IA, amplia cobertura documental, orquestación de flujos KYC.	Fortaleza en cobertura internacional; menor especialización en documentos ecuatorianos; costos superiores.
iProov	Prueba de vida (Genuine Presence Assurance) especializada contra inyección y deepfakes; usada por gobiernos.	Solo liveness; requiere combinarlo con OCR y comparación de otro proveedor.

Decisión D-12 · Amazon Rekognition (Face Liveness + CompareFaces) y Textract como proveedor principal, tras un adaptador intercambiable (Strategy) con Facephi / Incode como alternativas certificadas

1. **Integración y soberanía de datos:** el procesamiento biométrico ocurre en la misma región y cuenta de AWS, con IAM, KMS, VPC endpoints y CloudTrail; no se transfieren datos personales a un tercero adicional, lo que simplifica el cumplimiento de la LOPDP (minimización y transferencia internacional acotada a un encargado ya evaluado).
2. **Costo y elasticidad:** pago por verificación sin mínimos ni licencias de SDK, escalando con las campañas de captación; el SDK oficial cubre Flutter mediante integración nativa.
3. **Riesgo de proveedor mitigado por diseño:** el componente de Verificación Facial es un adaptador detrás de un puerto del dominio (patrón Strategy / Adapter); reemplazar el proveedor por Facephi o Incode —por exigencia de certificación PAD ISO/IEC 30107-3 nivel 2 explícita, soporte local o resultados de pruebas de aceptación— no altera el orquestador ni la app más allá del módulo SDK.

9.3 Integración con la autenticación y la autorización

El Onboarding y la autenticación comparten el mismo IdP y el mismo modelo de identidad: al completarse la verificación, el Servicio de Onboarding crea el usuario por SCIM 2.0 con estado "credenciales pendientes" y entrega a la app un token de enrolamiento de un solo uso; la app inicia entonces un flujo Authorization Code + PKCE con `prompt=create` en el IdP, donde el cliente define su clave y registra su passkey / huella (WebAuthn) y el dispositivo queda vinculado. A partir de ese momento las sesiones siguen el flujo estándar de la sección 8: usuario y clave + MFA, o huella / rostro (FIDO2), con step-up para transacciones. Los identificadores de la verificación (id de sesión de Onboarding, puntajes, decisión) se asocian al usuario en el IdP como atributos de aseguramiento (`ial`) que las políticas de autorización pueden consultar (p. ej. límites reducidos durante los primeros 30 días).

10. Acceso a datos e integración con el Core y sistemas externos

10.1 Capa de integración: API Gateway de integración y conectores ACL

La capa de integración es la única puerta de salida hacia los sistemas de registro y hacia terceros. Está formada por el **API Gateway de Integración (Kong Gateway)** desplegado en EKS dentro de la VPC y por **conectores anticorrupción (ACL)** por sistema destino. Sus responsabilidades son: autenticación mutua (mTLS) y credenciales por consumidor; ruteo por tipo de transacción (transferencia propia → Core; interbancaria → red ACH; pago de servicios → recaudador); mediación de protocolo (REST/JSON ↔ SOAP/XML, ISO 8583 / ISO 20022 cuando aplica); traducción entre el **modelo canónico** de BP y los contratos de cada sistema; políticas de resiliencia (timeouts, reintentos idempotentes, circuit breaker, rate limiting hacia el Core para no saturarlo); caché de lecturas de referencia (catálogos, bancos destino) y observabilidad (métricas por sistema legado). Los tres servicios principales exigidos por el enunciado —consulta de datos básicos, consulta de movimientos y transferencias— consumen esta capa, y se añadieron servicios de beneficiarios, productos y saldos, perfil digital, onboarding, auditoría y notificaciones.

> **Decisión D-13 · Kong Gateway + conectores ACL para la integración (frente a Amazon API Gateway privado, MuleSoft / WSO2 o llamadas directas desde los microservicios)**
>
> 1. **Protección del dominio frente al legado (Anti-Corruption Layer, DDD):** los contratos del Core (nomenclaturas, códigos, SOAP) no se filtran a los microservicios; cambiar o modernizar el Core solo afecta al conector. Llamadas directas acoplarían cada servicio a los detalles del legado.
> 2. **Capacidades de integración este-oeste:** Kong ofrece mTLS por consumidor, plugins de transformación, rate limiting, caché y despliegue dentro de la VPC junto a Direct Connect, con baja latencia; Amazon API Gateway está optimizado para exposición norte-sur y no media SOAP ni protocolos privados sin funciones intermedias.
> 3. **Costo y apertura:** Kong (código abierto con opción enterprise) evita el licenciamiento de un ESB (MuleSoft / WSO2) que sería sobredimensionado para un número acotado de integraciones; el modelo de conectores como microservicios Spring Boot permite pruebas de contrato y despliegues independientes.

10.2 Estrategia de acceso a datos

Dato	Fuente de verdad	Almacén en la plataforma	Regla de consistencia
Datos básicos del cliente, productos	Core Bancario	Redis (TTL 60 s), DynamoDB (vista clientes frecuentes)	Lectura desde vista / caché; invalidación por eventos CDC; refresco programado.
Detalle del cliente	CRM (sistema complementario)	Redis (TTL 5 min) solo campos necesarios	Se consulta bajo demanda cuando el canal requiere detalle; nunca replicado íntegramente.
Saldos	Core Bancario	Redis (TTL 30 s) para pantallas de consulta	Antes de una transacción siempre se lee en línea del Core (consistencia fuerte).
Movimientos	Core Bancario	DynamoDB (últimos 50 de clientes frecuentes), caché de páginas	Lectura por vista / caché con actualización por eventos; el histórico completo se pagina desde el Core.
Órdenes de transferencia, sagas, beneficiarios	Plataforma (Aurora, un esquema por servicio)	Aurora PostgreSQL Multi-AZ + Global Database	ACID local; estado final conciliado con el Core y la red por eventos y conciliación diaria.
Claves de idempotencia	Plataforma	DynamoDB con TTL 24 h	Escritura condicional atómica.
Sesiones del BFF, rate limiting	Plataforma	Redis (cluster, Multi-AZ, Global Datastore)	Datos volátiles con TTL; cifrados.

Dato	Fuente de verdad	Almacén en la plataforma	Regla de consistencia
Auditoría	Plataforma	Aurora append-only, S3 Object Lock, OpenSearch	Inmutable; ver §6.4.
Evidencias de Onboarding	Plataforma	S3 Object Lock + KMS por cliente	Inmutable; retención regulatoria.

Prácticas transversales: **base de datos por servicio** (sin esquemas compartidos), migraciones versionadas (Flyway), acceso con credenciales de corta vida (IAM database authentication) y Amazon RDS Proxy para el pool de conexiones; cifrado con KMS; enmascaramiento dinámico en réplicas de analítica; ningún dato de tarjeta en la plataforma (el pago de tarjetas se realiza por referencia / tokenización, manteniendo la plataforma fuera del alcance de almacenamiento PCI). El **flujo de cambios del Core (CDC)** se obtiene desde los eventos que publique el Core o, en su defecto, mediante Debezium sobre una réplica de lectura autorizada; el tópico `core-cdc` alimenta la invalidación de caché y la vista de clientes frecuentes.

Decisión D-14 · Poliglotismo de persistencia: Aurora PostgreSQL (transaccional), DynamoDB (vistas / idempotencia) y ElastiCache Redis (caché / sesiones)

Opciones evaluadas: Aurora PostgreSQL vs. RDS MySQL vs. Oracle RDS; DynamoDB vs. Apache Cassandra (Keyspaces) vs. MongoDB (DocumentDB); ElastiCache Redis vs. Memcached vs. Aurora como caché.

1. **Ajuste del modelo de datos al patrón de acceso (polyglot persistence):** las órdenes y sagas requieren ACID y consultas relacionales (Aurora PostgreSQL, con réplicas y Global Database); las vistas por cliente y las claves de idempotencia son accesos por clave con TTL y volumen elástico (DynamoDB, escrituras condicionales, Global Tables); la caché de sesiones y datos calientes requiere latencia sub-milisegundo y estructuras ricas (Redis).
2. **Alta disponibilidad y DR gestionadas:** los tres servicios ofrecen Multi-AZ, failover automático y replicación multi-región nativa (Aurora Global Database, DynamoDB Global Tables, Redis Global Datastore), cumpliendo RNF-05 sin tooling adicional.
3. **Estándares abiertos y costo:** PostgreSQL y Redis son estándares abiertos (portabilidad), sin licencias (a diferencia de Oracle); Cassandra / Keyspaces fue descartada por complejidad operativa frente a DynamoDB, y DocumentDB por no aportar sobre las vistas de documento simples que se requieren.

Decisión D-15 · Bus de eventos: Amazon MSK (Apache Kafka) con Debezium, complementado con SQS/SNS (frente a Amazon EventBridge o solo SQS/SNS)

1. **Durabilidad, orden y replay:** la auditoría exige que ningún evento se pierda y que pueda reprocesarse (p. ej. reconstruir el índice); Kafka retiene los eventos con orden por partición (por cliente) y permite múltiples grupos de consumidores independientes (auditoría, perfil digital, notificaciones, SIEM), mientras SQS elimina el mensaje al consumirse y EventBridge no garantiza orden ni retención larga.
2. **Ecosistema CDC / outbox:** Debezium (MSK Connect) implementa el patrón Transactional Outbox y el CDC del Core de forma estándar, y Kafka Streams resuelve el análisis de frecuencia con ventanas temporales sin infraestructura adicional.
3. **Pragmatismo:** SQS + Lambda se conserva para colas de trabajo simples (notificaciones) por su menor costo y complejidad; MSK Replicator permite replicar tópicos a la región DR.

10.3 Patrones de resiliencia en la integración

- **Timeouts y presupuestos de latencia** por dependencia (Core 2 s, CRM 1,5 s, antifraude 800 ms, ACH 5 s) para no propagar lentitud.
- **Reintentos con back-off exponencial y jitter**, solo en operaciones idempotentes (lecturas y operaciones del Core que aceptan clave de idempotencia).
- **Circuit breaker y bulkhead** (Resilience4j y outlier detection de Istio): aíslan las fallas de un sistema legado sin agotar hilos ni conexiones.

- **Degradación controlada:** con el Core caído, las consultas se sirven desde vistas / caché con marca temporal y las transacciones se rechazan de forma segura (nunca "en duda").
- **Conciliación:** proceso diario que compara órdenes de la plataforma con los movimientos del Core y los acuses de la red, y genera alertas y casos de operación.

10.4 Flujo de una transferencia interbancaria

La Figura 13 integra los elementos anteriores en el flujo completo de una transferencia interbancaria: validación de token y step-up, idempotencia, límites, saldo en línea, antifraude, saga (orden pendiente → débito en el Core → envío ISO 20022 → aceptación 202), publicación por outbox, notificación por dos canales y confirmación asíncrona de la red con compensación en caso de rechazo.

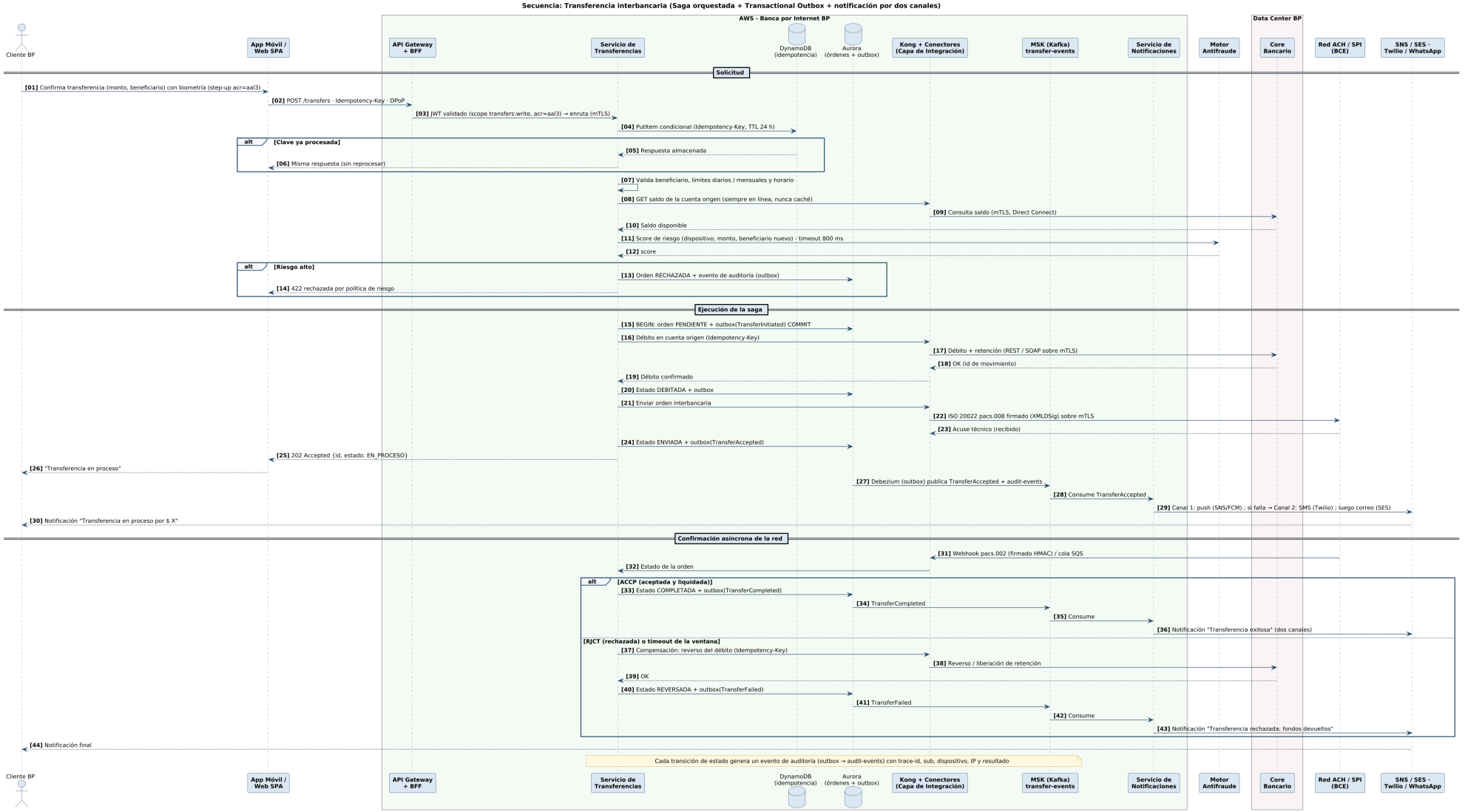


Figura 13. *Diagrama de secuencia de una transferencia interbancaria (saga orquestada, outbox y notificación por dos canales).*

11. Notificación de movimientos por múltiples canales

Cada movimiento (transferencias enviadas y recibidas, pagos, débitos, cambios de estado) y cada evento de seguridad relevante (inicio de sesión desde un dispositivo nuevo, alta de beneficiario, cambio de clave) genera una notificación al cliente por **al menos dos canales**. El Servicio de Notificaciones es serverless (Lambda + SQS) y aplica el siguiente diseño:

Aspecto	Diseño
Canales y proveedores	**Sistema 1 – AWS:** Amazon SNS (push a FCM / APNs y SMS) y Amazon SES (correo con DKIM / DMARC). **Sistema 2 – externo:** Twilio (SMS con rutas alternas) y WhatsApp Business API (plantillas aprobadas). Todos accesibles tras adaptadores del patrón *Strategy*.
Política de doble canal	Por defecto: push + correo; si el cliente elige WhatsApp: WhatsApp + push; los eventos de seguridad usan siempre un canal fuera del dispositivo actual (correo o SMS). El cliente administra preferencias con verificación previa del número / correo.
Contingencia	*Chain of Responsibility*: si un proveedor devuelve error o no confirma entrega en N minutos, se envía por el siguiente canal / proveedor; se alterna entre SNS y Twilio para SMS según la salud del proveedor (circuit breaker).
Garantías	Consumo idempotente por `event_id`, reintentos con back-off, cola de mensajes fallidos (DLQ) con alerta operativa, y registro de acuses (webhooks de Twilio / WhatsApp, eventos de entrega de SES / SNS) como evidencia auditable.
Contenido y privacidad	Plantillas versionadas y aprobadas por Cumplimiento; datos enmascarados (cuenta ****1234, monto y fecha); sin enlaces clicables a login (antiphishing); sin PII en el payload de push (solo referencia; el detalle se obtiene autenticado).
Escala y costo	Lambda escala con la cola; costo por mensaje; límites de tasa por proveedor; agrupación de notificaciones no críticas.

La justificación de la elección de los dos sistemas se presenta en la decisión D-02 (sección 4).

12. Infraestructura en AWS: alta disponibilidad, DR, latencia y auto-healing

12.1 Selección de la nube

Decisión D-16 · Nube pública: AWS (frente a Microsoft Azure)

Criterio	AWS	Azure
Latencia desde Ecuador	us-east-1 (Virginia) a ~70–100 ms; borde CloudFront y Global Accelerator con puntos de presencia en la región; Direct Connect disponible vía socios locales.	Regiones más cercanas consolidadas en Brasil (mayor latencia por ruta de red hacia Ecuador); Front Door y ExpressRoute equivalentes.
Servicios gestionados requeridos	EKS, Aurora Global DB, DynamoDB Global Tables, MSK, ElastiCache Global Datastore, OpenSearch, Rekognition Face Liveness, Textract, KMS / CloudHSM, Shield Advanced, Control Tower.	AKS, Cosmos DB, Event Hubs (compatible Kafka), Azure Cache, Azure AI Vision (liveness), Key Vault / Managed HSM, DDoS Protection: cobertura equivalente, con menor madurez en liveness gestionado y en replicación multi-región de PostgreSQL.
Cumplimiento y confianza en banca	Certificaciones PCI DSS, ISO 27001/27017/27018, SOC 1/2/3; amplia adopción por bancos y fintech de la región; programa de Well-Architected Financial Services Lens.	Certificaciones equivalentes; fuerte donde existe ecosistema Microsoft 365 / Entra ID.
Costos	Graviton (hasta 40 % mejor precio-rendimiento), Savings Plans, capa gratuita amplia de observabilidad.	Reservas y Hybrid Benefit (relevante solo con licencias Microsoft).

1. **Menor latencia y borde global:** la región us-east-1 y la red de borde de AWS ofrecen la mejor latencia esperada desde Ecuador entre las regiones con el catálogo completo de servicios, cumpliendo RNF-02 (a validar con pruebas de latencia previas al despliegue); Global Accelerator y CloudFront reducen el tiempo de conexión y absorben ataques volumétricos.
2. **Cobertura del catálogo de servicios críticos para el diseño:** replicación multi-región gestionada de todos los almacenes elegidos (Aurora Global Database, DynamoDB Global Tables, Redis Global Datastore, MSK Replicator, S3 CRR) y verificación biométrica gestionada (Rekognition Face Liveness) que evitan integrar terceros adicionales.
3. **Madurez en el sector financiero y gobernanza:** AWS Control Tower, SCPs, Security Hub y el *Financial Services Lens* aceleran el cumplimiento evidenciable exigido por la Superintendencia (riesgo operativo, contingencia) y por PCI DSS. Azure sería la elección natural si BP tuviera un ecosistema Microsoft consolidado (Entra ID como IdP corporativo, M365); el diseño lógico (C4) es portable y solo cambiarían los servicios gestionados equivalentes.

12.2 Diagrama de despliegue

La Figura 14 muestra la topología física: dispositivos del cliente; borde global (Route 53, CloudFront, WAF, Shield Advanced, Global Accelerator); región primaria us-east-1 con API Gateway, VPC de tres zonas de disponibilidad (EKS con nodos Graviton y Karpenter, Aurora Multi-AZ, ElastiCache, MSK con tres brokers, OpenSearch) y servicios regionales gestionados (DynamoDB, S3, Lambda / SQS / SNS / SES, KMS / CloudHSM, seguridad y monitoreo); región DR us-east-2 en *warm standby*; el data center de BP con el Core, el CRM, el IdP y el antifraude conectados por Direct Connect redundante; y los terceros (red ACH, Twilio).

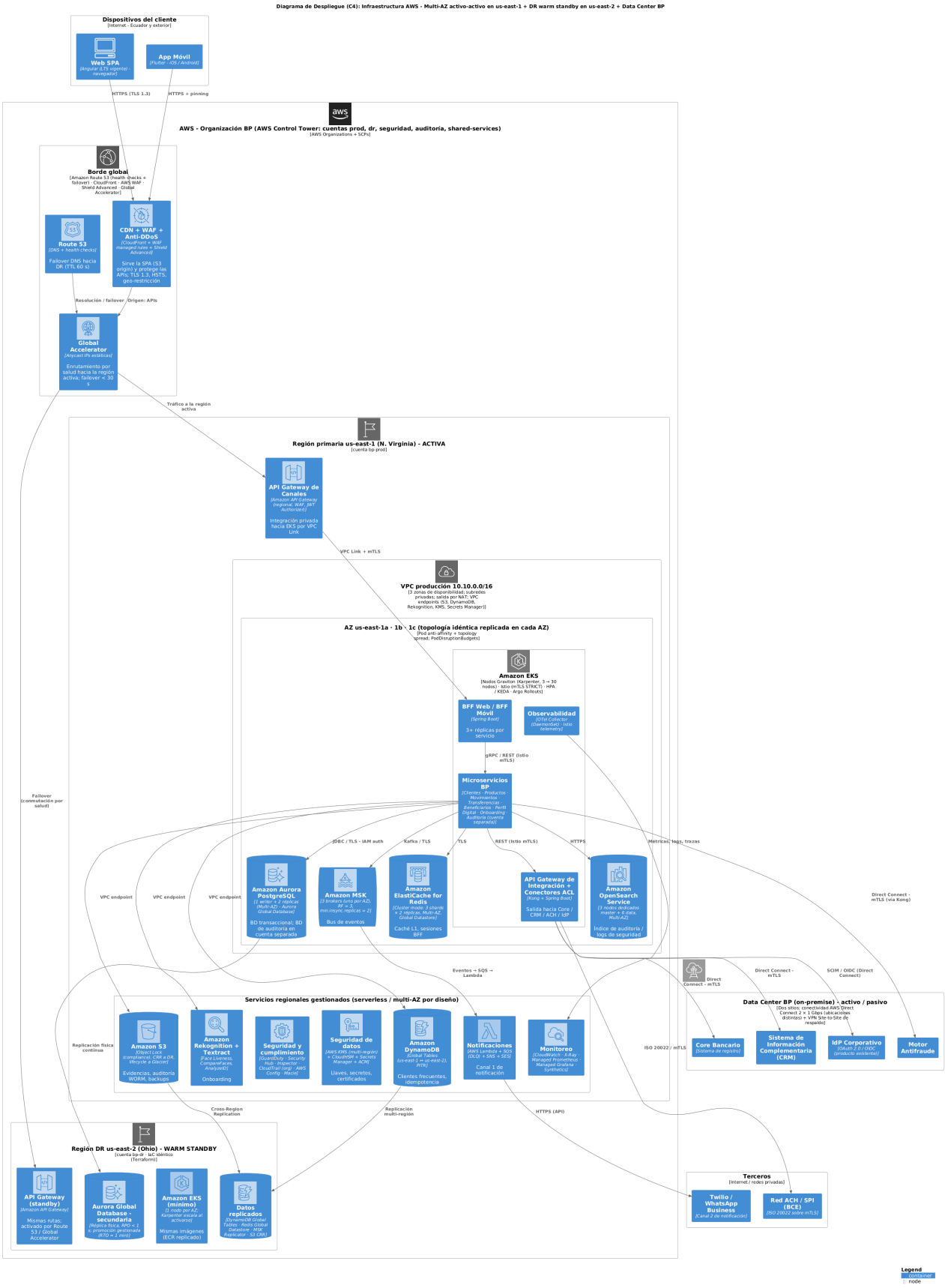


Figura 14. *Diagrama de despliegue en AWS: Multi-AZ activo-activo, DR warm standby multi-región y conectividad privada con el data center de BP.*

12.3 Organización de cuentas y red

- **AWS Organizations + Control Tower:** cuentas separadas para producción, DR, seguridad (GuardDuty / Security Hub delegados), auditoría (Servicio de Auditoría, CloudTrail de la organización y S3 WORM), servicios compartidos (CI/CD, ECR, Transit Gateway) y ambientes no productivos; políticas SCP que impiden desactivar CloudTrail, borrar Object Lock, salir de la región permitida o crear recursos sin cifrado.
- **Red:** VPC por cuenta con subredes privadas en tres AZ; sin IPs públicas en cargas de trabajo; salida por NAT y VPC endpoints (S3, DynamoDB, KMS, Secrets Manager, Rekognition, Textract, ECR, CloudWatch) para que el tráfico a servicios AWS no salga a Internet; Transit Gateway para conectar cuentas y los enlaces Direct Connect; grupos de seguridad y NACL de mínimo privilegio; Network Firewall para inspección de egreso.
- **Conectividad con el data center:** dos enlaces AWS Direct Connect de 1 Gbps en ubicaciones distintas (LAG / BGP con failover) más VPN Site-to-Site como respaldo; MACsec / IPsec para cifrado en el enlace; latencia objetivo < 20 ms hacia el Core.
- **Latencia para el cliente:** CloudFront sirve la SPA y cachea respuestas idempotentes públicas; Global Accelerator enruta las APIs por la red troncal de AWS; se evaluará una AWS Local Zone en la región (cuando esté disponible con los servicios requeridos) para reducir aún más la latencia del borde.

Decisión D-17 · Plataforma de ejecución: Amazon EKS con nodos Graviton, Karpenter e Istio (frente a ECS/Fargate, y Linkerd / App Mesh como malla)

1. **Estándar abierto y ecosistema:** Kubernetes permite usar Istio (mTLS STRICT, políticas de autorización L7, outlier detection, telemetría), Argo CD / Rollouts (GitOps y despliegue progresivo), KEDA (escalado por consumer lag) y Karpenter (aprovisionamiento just-in-time), capacidades clave para auto-healing y excelencia operativa; ECS/Fargate simplifica la operación pero limita la malla y el escalado por eventos.
2. **Costo-rendimiento:** nodos Graviton (ARM) con Savings Plans y consolidación por Karpenter reducen el costo de cómputo; Fargate se reserva para tareas puntuales.
3. **Malla de servicios:** Istio se elige por sus políticas de seguridad L7 y madurez; AWS App Mesh fue descartado por su fin de soporte anunciado y Linkerd por menor cobertura de políticas de autorización.

12.4 Alta disponibilidad y tolerancia a fallos

Capa	Mecanismo de alta disponibilidad	Falla tolerada
Borde	Route 53 (100 % SLA), CloudFront y Global Accelerator anycast con health checks; Shield Advanced con respuesta 24×7.	Pérdida de un punto de presencia; ataque DDoS L3–L7.
API Gateway	Servicio regional multi-AZ; standby en DR.	Falla de AZ.
Cómputo (EKS)	Plano de control gestionado multi-AZ; nodos en 3 AZ; réplicas ≥ 3 por servicio con anti-affinity y topology spread; PodDisruptionBudgets; probes; HPA / KEDA; Karpenter reemplaza nodos degradados.	Caída de una AZ, de nodos o de pods; picos de carga.
Datos	Aurora Multi-AZ (failover < 30 s, réplicas de lectura), DynamoDB (multi-AZ nativo), Redis cluster con réplicas Multi-AZ, MSK con RF = 3 y `min.insync.replicas` = 2, OpenSearch multi-AZ con masters dedicados.	Caída de una AZ o de un nodo de datos sin pérdida de datos confirmados.
Integración	Kong con ≥ 3 réplicas; Direct Connect redundante + VPN; circuit breakers hacia el Core.	Caída de un enlace o de un conector; degradación del Core.
Dependencias externas	Dos proveedores de notificación; adaptador intercambiable de KYC; colas con reintentos y DLQ.	Caída de un proveedor.

Cálculo de disponibilidad (referencial): con componentes redundantes en tres AZ y servicios gestionados con SLA ≥ 99,99 %, la disponibilidad compuesta de la ruta crítica (borde → API Gateway → EKS → Aurora/Redis → Core vía Direct Connect) se estima en 99,95–99,97 %, condicionada por la disponibilidad del Core y de la red interbancaria, que se mitiga con degradación controlada (consultas desde vistas) y con rechazo seguro de transacciones.

12.5 Recuperación ante desastres

> **Decisión D-18 · Estrategia DR multi-región warm standby (frente a backup & restore, pilot light y activo-activo multi-región)**
>
> 1. **Objetivos RTO / RPO alineados con la criticidad y la norma:** la normativa de riesgo operativo exige planes de continuidad probados; warm standby ofrece RTO ≤ 30 min y RPO ≤ 1 min con replicación continua (Aurora Global Database, DynamoDB Global Tables, Redis Global Datastore, MSK Replicator, S3 CRR), superando a backup & restore (RTO de horas) y a pilot light (RTO ~1 h por el arranque de la plataforma).
> 2. **Costo proporcionado:** un activo-activo multi-región duplicaría el costo y añadiría complejidad de escrituras en dos regiones (conflictos, latencia hacia el Core on-premise); el warm standby mantiene una copia mínima escalable con Karpenter y cuesta ~15–20 % de la región primaria.
> 3. **Verificabilidad:** la infraestructura de ambas regiones es idéntica por código (Terraform), lo que permite pruebas de conmutación trimestrales, game days y evidencia auditable para el regulador.

- **Procedimiento de conmutación:** detección (health checks, alarmas compuestas) → decisión (runbook en Incident Manager, aprobación del comité de crisis para conmutaciones totales; automática para fallas de AZ) → promoción de Aurora Global Database (managed failover), escalado de EKS en DR, cambio de Route 53 / Global Accelerator → verificación sintética → comunicación.
- **Backups:** snapshots automáticos de Aurora (35 días) con copia a la cuenta de auditoría y a DR (AWS Backup con bóveda inmutable), PITR en DynamoDB, exportaciones de Kafka; pruebas de restauración mensuales.
- **Dependencias on-premise:** el Core y el IdP tienen su propio plan de contingencia (sitio alterno); Direct Connect y VPN conectan ambas regiones de AWS con ambos sitios de BP.

12.6 Auto-healing y escalado

- **Kubernetes:** liveness / readiness / startup probes, reinicio automático, PodDisruptionBudgets, reprogramación ante nodos no saludables (Node Problem Detector + Karpenter), HPA por CPU / latencia p99 y KEDA por consumer lag de Kafka y profundidad de SQS.
- **Malla y librerías:** outlier detection y reintentos en Istio; circuit breakers, bulkheads y timeouts en Resilience4j; rate limiting adaptativo.
- **Servicios gestionados:** failover automático de Aurora, ElastiCache y MSK; escalado de DynamoDB on-demand y Lambda; Route 53 / Global Accelerator con health checks.
- **Remediación automatizada:** Systems Manager Automation ejecuta runbooks disparados por EventBridge (rotar secretos comprometidos, aislar un nodo, reciclar conexiones al Core, purgar caché corrupta); ingeniería de caos con AWS Fault Injection Service valida periódicamente estos mecanismos.

13. Seguridad y cumplimiento normativo

13.1 Marco regulatorio y estándares aplicables

Norma / estándar	Requisitos relevantes	Controles de la arquitectura
Ley Orgánica de Protección de Datos Personales (Ecuador, 2021) y su Reglamento	Base legal y consentimiento; datos biométricos como categoría especial; minimización; derechos ARCO / portabilidad; seguridad; notificación de brechas a la Autoridad; transferencias internacionales; Delegado de Protección de Datos.	Consentimiento registrado con evidencia; minimización y tokenización; cifrado KMS; retención definida; APIs para derechos ARCO; encargados evaluados (AWS, Twilio); registro de actividades de tratamiento; DPIA del Onboarding biométrico.
Código Orgánico Monetario y Financiero y normativa de la Superintendencia de Bancos (riesgo operativo, seguridad de la información, continuidad del negocio, canales electrónicos y transacciones)	Sigilo bancario; gestión de riesgo operativo; seguridad en canales electrónicos; autenticación robusta; notificación de transacciones al cliente; planes de contingencia y continuidad probados; registro y conservación de transacciones.	MFA y step-up; notificación por dos canales; auditoría inmutable; DR probado (RTO / RPO); segregación de funciones; controles de acceso y monitoreo 24×7; conservación de registros ≥ plazos legales.
Ley Orgánica de Prevención, Detección y Erradicación del Delito de Lavado de Activos y Financiamiento de Delitos (UAFE)	Debida diligencia del cliente (KYC), listas de control, PEP, reportes de operaciones inusuales.	Onboarding con verificación de identidad y screening AML / PEP; casos a revisión manual; eventos y reportes desde auditoría.
Ley de Comercio Electrónico, Firmas Electrónicas y Mensajes de Datos	Validez de mensajes de datos y firmas electrónicas; conservación e integridad.	Firmas criptográficas (KMS), sellos de tiempo, cadena de hashes; consentimiento electrónico verificable.
Normativa del Banco Central (SPI) y de la red interbancaria	Formatos, ventanas de compensación, seguridad de la conexión.	Conector ACH con ISO 20022, firma XMLDSig, mTLS, conciliación diaria.
PCI DSS 4.0 (aplicable a datos de tarjeta cuando existan pagos con tarjeta)	Segmentación, cifrado, gestión de llaves, registro y monitoreo, pruebas de seguridad, MFA para acceso administrativo.	Sin almacenamiento de PAN (tokenización por referencia); KMS / CloudHSM; segmentación por cuentas y VPC; SAST / DAST; MFA + acceso just-in-time para administradores.
ISO/IEC 27001 / 27002, ISO 22301, NIST CSF 2.0, SOC 2	SGSI, continuidad, gobierno, identificación / protección / detección / respuesta / recuperación.	Controles mapeados en Security Hub (CIS AWS Foundations, PCI); ISO 22301 con el plan DR; políticas como código (AWS Config, OPA).
NIST SP 800-63B, FAPI 2.0, RFC 9700, OWASP ASVS 4 / MASVS 2 / API Security Top 10	Niveles de aseguramiento de autenticación (AAL2 / AAL3), OAuth seguro, requisitos de verificación de aplicaciones web / móviles / APIs.	Passkeys FIDO2 (AAL3), Code + PKCE + PAR + DPoP, ASVS L2 (L3 en autenticación / transacciones), MASVS-L2 + R, controles API en el gateway.
Referencias regionales e internacionales (Colombia: SFC Circular Externa 007/2018 y 029/2014, Ley 1581/2012; Perú: SBS; UE: PSD2 SCA, GDPR; FATF)	Autenticación fuerte de clientes, seguridad de canales, protección de datos, KYC.	El diseño cubre estas exigencias por equivalencia funcional; la adaptación jurisdiccional afecta parámetros (plazos de retención, umbrales, reportes), no la arquitectura.

13.2 Modelo de seguridad (defensa en profundidad / Zero Trust)

Dominio	Controles
Identidad y acceso de clientes	OAuth 2.0 / OIDC (Code + PKCE, FAPI 2.0, PAR, DPoP); MFA phishing-resistente; step-up con vinculación dinámica de la transacción; bloqueo progresivo y detección de credential stuffing; gestión de dispositivos; sesiones cortas con revocación.
Identidad y acceso de personal y cargas	SSO corporativo con MFA, roles IAM con mínimo privilegio y acceso just-in-time (sin credenciales de larga duración), IAM Roles for Service Accounts / Pod Identity en EKS, mTLS STRICT en la malla, políticas de autorización L7 (AuthorizationPolicy).
Red y perímetro	WAF (reglas gestionadas OWASP, bot control, rate-based), Shield Advanced, Global Accelerator, sin IPs públicas, VPC endpoints, Network Firewall de egreso, segmentación por cuentas / VPC / namespaces, NACL y grupos de seguridad de mínimo privilegio.

Dominio	Controles
Protección de datos	TLS 1.3 en tránsito (pinning en móvil), cifrado en reposo con KMS (llaves por servicio y por clasificación, rotación anual), CloudHSM para llaves de firma de transacciones, cifrado a nivel de campo y tokenización de cuentas / documentos, enmascaramiento en logs y pantallas, Amazon Macie para descubrimiento de PII, clasificación de datos y retención.
Seguridad de aplicaciones (DevSecOps)	Modelado de amenazas (STRIDE) por servicio; SAST, SCA (SBOM), secret scanning y análisis IaC en el pipeline; DAST y pruebas de API en preproducción; firma de imágenes (Sigstore / cosign) y política de admisión; imágenes mínimas (distroless) escaneadas con Inspector; pentest anual y bug bounty; revisión de seguridad para cambios en autenticación y transferencias.
Seguridad de la plataforma	Hardening CIS de EKS y nodos (Bottlerocket), Pod Security Standards (restricted), políticas Kyverno / OPA Gatekeeper, secretos en Secrets Manager con rotación, sin acceso SSH (Session Manager), parcheo automatizado, backups inmutables.
Detección y respuesta	CloudTrail organizacional, GuardDuty (incl. EKS runtime), Security Hub, Inspector, Detective, VPC Flow Logs, reenvío al SIEM del SOC; playbooks de respuesta; ejercicios de incidentes; notificación de brechas conforme a la LOPDP.
Antifraude	Puntaje de riesgo en cada transacción (dispositivo, geolocalización, comportamiento, beneficiario nuevo), límites por canal y por nivel de autenticación, período de enfriamiento para beneficiarios nuevos, notificación inmediata por dos canales, bloqueo desde la app.
Gobierno y cumplimiento continuo	AWS Config con reglas de conformidad (cifrado, logging, Object Lock), SCPs, revisiones Well-Architected (pilar seguridad y Financial Services Lens), evidencia automatizada para auditorías (Audit Manager), gestión de proveedores (AWS, Twilio, KYC) bajo contratos de encargado de tratamiento.

14. Monitoreo, observabilidad y excelencia operativa

14.1 Arquitectura de observabilidad

La Figura 15 presenta el flujo de señales: fuentes (RUM, borde, API Gateway, microservicios instrumentados con OpenTelemetry e Istio, datos y mensajería, seguridad y monitoreo sintético), recolección y almacenamiento (OTel Collector, Managed Prometheus, CloudWatch Logs, X-Ray, OpenSearch, Security Hub), visualización, SLOs y alertamiento (Managed Grafana, alarmas, EventBridge, SNS → PagerDuty / Opsgenie) y respuesta con auto-healing (Kubernetes, malla, failover gestionado, runbooks automatizados, ingeniería de caos y SOC).

Práctica	Implementación
Golden signals y SLOs	Latencia, tráfico, errores y saturación por servicio y por canal; SLOs de disponibilidad (99,95 %), latencia (p99 < 800 ms consultas, < 2 s transferencias) y frescura de la vista de clientes frecuentes (< 2 s); error budgets que regulan el ritmo de despliegues; alertas por síntoma (burn rate 2 %/h y 5 %/6 h) y no por causa, para evitar fatiga de alertas.
Trazabilidad extremo a extremo	Propagación de `traceparent` desde la app y la SPA hasta el Core (cabeceras en Kong); correlación de trazas, logs y eventos de auditoría por trace-id; muestreo tail-based que conserva el 100 % de errores y transacciones.
Logs	JSON estructurado, sin PII (enmascarado en origen), retención 13 meses en CloudWatch y 90 días en OpenSearch para seguridad; logs de auditoría en su propio circuito (§6.4).
Monitoreo sintético y RUM	Canaries que ejecutan login, consulta y transferencia de prueba cada minuto desde tres ubicaciones; RUM en la SPA (Core Web Vitals) y crash reporting en la app.
Monitoreo de negocio	Transacciones por minuto, tasa de aprobación, montos, notificaciones entregadas por canal, conversiones del Onboarding, fraude detectado; dashboards para Operaciones y Cumplimiento.
Seguridad	GuardDuty, Security Hub, Inspector y CloudTrail hacia el SIEM del SOC (Splunk / Sentinel) con casos de uso de detección (accesos anómalos, cambios de configuración, exfiltración).
On-call y respuesta	Rotaciones 24×7 (SRE y Seguridad), escalamiento automático, Incident Manager con runbooks, postmortems sin culpa y seguimiento de acciones.

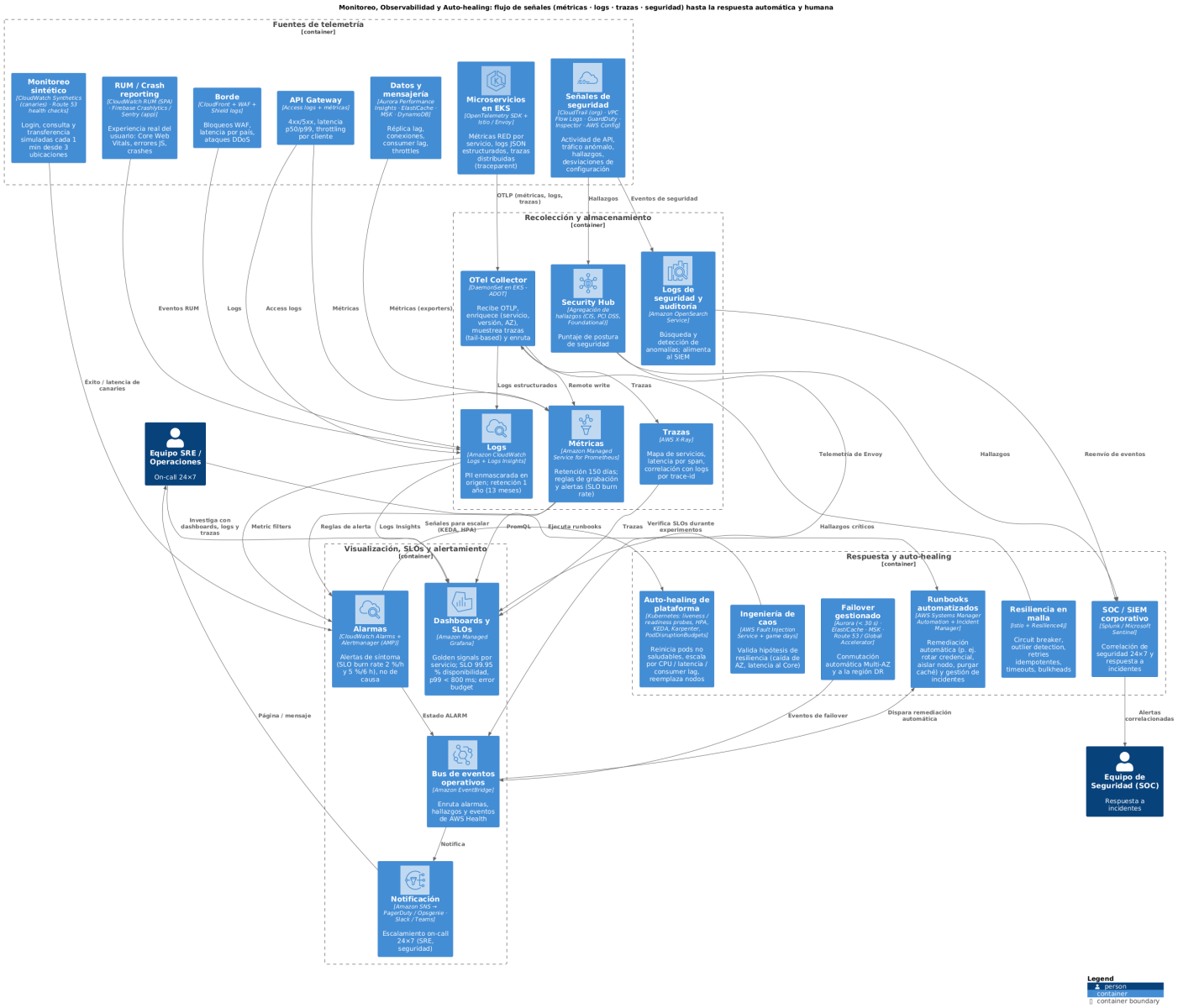


Figura 15. *Arquitectura de monitoreo, observabilidad y auto-healing.*

Decisión D-19 · Observabilidad con OpenTelemetry + Amazon Managed Prometheus / Grafana + CloudWatch / X-Ray (frente a Datadog / New Relic o ELK autogestionado)

1. **Estándar abierto sin bloqueo:** la instrumentación con OpenTelemetry (SDK y Collector) es independiente del backend; permite cambiar a un SaaS de observabilidad en el futuro sin reinstrumentar los servicios.
2. **Integración nativa y costo:** los servicios gestionados de AWS ingieren métricas de EKS, Aurora, MSK, API Gateway, WAF y Lambda sin agentes adicionales, con costo por uso muy inferior al de plataformas SaaS a este volumen (§15) y sin la carga operativa de un ELK propio.
3. **Cumplimiento:** la telemetría permanece dentro de la cuenta y región de BP (residencia de datos y control de PII), y se integra con el SIEM corporativo por reenvío controlado.

14.2 Excelencia operativa: entrega y operación como código

- **Infraestructura como código:** Terraform (módulos versionados, Terraform Cloud / Atlantis con revisión y análisis de políticas) para ambas regiones; Helm / Kustomize para las cargas; políticas como código (OPA / Kyverno, AWS Config).
- **CI/CD DevSecOps:** pipelines por servicio (GitHub Actions / GitLab CI): build → pruebas unitarias y de contrato (Pact) → SAST / SCA / secretos → imagen firmada → despliegue GitOps con Argo CD → pruebas de integración y DAST en preproducción → despliegue progresivo en producción con Argo Rollouts (canary con análisis automático de SLOs y rollback; blue-green para cambios de esquema) → verificación sintética. Feature flags para activar funcionalidades sin redespliegue.
- **Ambientes:** desarrollo, integración, QA, preproducción (réplica de producción con datos enmascarados) y producción; datos sintéticos para pruebas; entornos efímeros por rama.
- **Gestión de cambios y de incidentes:** ventanas sin freeze gracias a despliegues progresivos; CAB solo para cambios de alto riesgo (autenticación, integración con el Core); runbooks versionados; game days y pruebas de DR trimestrales; revisión Well-Architected semestral.
- **Documentación viva:** diagramas como código (PlantUML / C4) en el repositorio, ADRs, catálogo de APIs (OpenAPI / AsyncAPI) y de eventos, y catálogo de servicios (Backstage).

15. Gestión de costos (FinOps)

15.1 Prácticas de optimización

- **Visibilidad:** etiquetado obligatorio (servicio, canal, ambiente, centro de costo), Cost Explorer y CUR con dashboards por servicio; presupuestos con alertas al 80 % y anomalías (Cost Anomaly Detection).
- **Compromisos y arquitectura:** Compute Savings Plans (3 años) para EKS y Lambda; nodos Graviton (ARM); instancias reservadas para Aurora, ElastiCache, OpenSearch y MSK; Spot solo para cargas no críticas (pruebas, procesamiento por lotes).
- **Right-sizing continuo:** Karpenter consolida nodos; Compute Optimizer y métricas de utilización; Aurora Serverless v2 para ambientes no productivos; apagado automático de entornos fuera de horario.
- **Datos:** lifecycle de S3 (Standard → Intelligent-Tiering → Glacier Deep Archive para auditoría antigua), TTL en DynamoDB y Redis, retención de logs diferenciada, compresión en Kafka.
- **Red:** VPC endpoints para evitar cargos de NAT, CloudFront para reducir egreso desde la región, consolidación de Direct Connect.
- **DR proporcionado:** warm standby mínimo con escalado bajo demanda; revisión trimestral del tamaño del standby.

15.2 Estimación referencial de costos mensuales (producción + DR)

Estimación de orden de magnitud para el volumen de referencia (SUP-06), precios de lista en us-east-1 con Savings Plans a 3 años donde aplica; margen ±30 %. Debe validarse con AWS Pricing Calculator y con las cotizaciones de Twilio / WhatsApp y del enlace Direct Connect del socio local.

Componente	Dimensionamiento supuesto	USD / mes	Notas
Amazon EKS (2 clústeres) + nodos Graviton	Plano de control ×2; 9–12 nodos m7g.xlarge promedio	1.800	Karpenter + Savings Plans
Amazon Aurora PostgreSQL	Writer + 2 réplicas r7g.large, 500 GB, I/O optimizado	1.200	Un clúster compartido por servicio con esquemas separados; auditoría en cuenta aparte
Aurora Global Database (réplica DR)	1 instancia en us-east-2 + transferencia	700	Parte del DR
Amazon DynamoDB	Global Tables, on-demand, 50 GB, 30 M lecturas / 10 M escrituras	200	
Amazon ElastiCache for Redis	3 shards × 2 réplicas cache.r7g.large + Global Datastore	600	
Amazon MSK	3 brokers kafka.m7g.large, 1 TB, MSK Connect	700	Incluye Debezium
Amazon OpenSearch Service	3 masters + 6 data r7g.large, 2 TB	900	Auditoría y seguridad
Amazon API Gateway	50 M peticiones / mes + caché	175	
CloudFront + WAF + Shield Advanced	5 TB egreso, reglas gestionadas, Shield Advanced (cuota fija)	3.300	Shield Advanced ≈ USD 3.000 fijos, opcional según apetito de riesgo
Red: NAT, VPC endpoints, Direct Connect (2 × 1 Gbps)	Puertos DX + egreso	400	Sin costo del socio de conectividad local
Lambda + SQS + SNS + SES	20 M invocaciones, 5 M push, 1 M SMS AWS, 3 M correos	300	SMS varía por país

Componente	Dimensionamiento supuesto	USD / mes	Notas
Twilio / WhatsApp Business	1 M SMS + 2 M conversaciones WhatsApp	Variable	Cotizar; típicamente USD 5.000–15.000 según mix
Amazon Rekognition + Textract	20.000 Onboardings / mes (liveness, comparación, OCR)	400	Escala con captación
Observabilidad (CloudWatch, AMP, AMG, X-Ray, Synthetics)	300 GB logs, 5 M métricas, trazas muestreadas	800	
Seguridad (GuardDuty, Security Hub, Inspector, KMS, CloudHSM, Secrets Manager, Macie)	2 cuentas prod, CloudHSM 2 nodos	500	CloudHSM es el mayor componente (opcional si el IdP firma)
Backups y S3	AWS Backup, S3 Object Lock, CRR, Glacier	200	
DR warm standby (EKS mínimo, Redis, MSK Replicator, API GW)	Excluye la réplica de Aurora ya contada	2.500	Escala solo al activarse
Total AWS estimado		**≈ 14.700**	**Rango 14.000–16.000 sin mensajería externa**

Decisión D-20 · Modelo de costos: servicios gestionados + compromisos de largo plazo (frente a infraestructura autogestionada en EC2 para ahorrar licencias de servicios)

1. **Costo total de propiedad:** operar Kafka, PostgreSQL, Redis y OpenSearch en EC2 reduciría la factura de AWS entre 20 y 30 %, pero requeriría al menos cuatro ingenieros adicionales de plataforma 24×7 y elevaría el riesgo operativo (parcheo, failover manual), superando ampliamente el ahorro.
2. **Elasticidad y alineación con el uso:** los servicios gestionados escalan con la demanda y se pagan por uso; los Savings Plans y Graviton capturan el ahorro de la línea base estable (cómputo, bases de datos) sin comprometer capacidad de pico.
3. **Riesgo regulatorio:** los servicios gestionados aportan certificaciones y controles auditables (ISO, PCI, SOC) que serían costosos de evidenciar sobre infraestructura autogestionada.

16. Registro de decisiones de arquitectura (ADR)

La tabla consolida las decisiones distribuidas a lo largo del documento, con las opciones evaluadas y las dos o más justificaciones principales de cada una. Cada decisión se mantiene como un ADR individual en el repositorio (`docs/adr/`) para su trazabilidad y revisión.

ID	Decisión	Opciones evaluadas	Justificaciones principales	Sección
D-01	Microservicios en contenedores con orientación a eventos	Monolito modular; microservicios en EKS; serverless puro	Aislamiento y escalado independiente de consultas vs. transacciones; reutilización por canales; madurez operativa y portabilidad de Kubernetes.	§3
D-02	Dos sistemas de notificación: SNS/SES + Twilio/WhatsApp	Solo AWS; solo Twilio + SendGrid; Pinpoint; pasarela local + SMTP	Independencia de proveedores (mandato normativo); cobertura de canales y evidencia de entrega; alternativas con menor foco transaccional.	§4
D-03	REST en el borde, gRPC interno, eventos por Kafka	REST en todo; gRPC + REST; todo asíncrono	Eficiencia y contratos tipados; desacople temporal para auditoría / notificaciones; simplicidad para consultas síncronas.	§5.2
D-04	Amazon API Gateway con JWT Authorizer para canales	Kong / Apigee / NGINX autogestionado	Gestionado y elástico con WAF; autorización estándar en el borde; separación norte-sur / este-oeste.	§5.2
D-05	Patrón BFF por canal	API única genérica; gateway con lógica	Composición por canal sin contaminar dominios; seguridad diferenciada (Token Handler vs. DPoP); evolución independiente.	§5.2
D-06	Saga orquestada + Outbox + Idempotent Receiver	2PC / XA; saga coreografiada	2PC inviable con legado y red; visibilidad del estado; publicación confiable y sin duplicados.	§6.1
D-07	Angular para la SPA	React; Vue	Seguridad y convenciones integradas; ciclo LTS y herramientas de migración; formularios reactivos para flujos transaccionales.	§7
D-08	Flutter para la app móvil	React Native; nativo; Kotlin Multiplatform	Rendimiento y consistencia con código AOT; ecosistema de seguridad (MASVS-R); menor costo y un ciclo de release.	§7
D-09	Authorization Code + PKCE (FAPI 2.0, PAR, DPoP); SPA vía BFF; móvil con AppAuth	Implicit; ROPC; Code sin PKCE; Hybrid	Alineación con RFC 9700 / 8252 / OAuth 2.1; tokens fuera del navegador y ligados al dispositivo; exigencias del sector financiero (FAPI).	§8
D-10	Auditoría por eventos, cuenta separada, cadena de hashes firmada y WORM	Triggers en BD; logs de aplicación; QLDB / blockchain	Completitud y atomicidad (interceptor + outbox + logs de gateway); integridad verificable y segregación de funciones; sin impacto en latencia.	§6.4
D-11	Vista materializada por eventos para clientes frecuentes (DynamoDB + Redis)	Solo caché TTL; réplica completa del Core	Rendimiento con consistencia acotada; menor carga y costo en el Core; minimización de datos.	§6.5
D-12	Rekognition Face Liveness + CompareFaces + Textract tras adaptador; Facephi / Incode como alternativas	Facephi; Incode; Jumio / Onfido / Veriff; iProov	Integración y soberanía de datos en la misma región; costo por uso; riesgo de proveedor mitigado con Strategy / Adapter.	§9
D-13	Kong + conectores ACL para integración	Amazon API Gateway privado; MuleSoft / WSO2; llamadas directas	ACL protege el dominio del legado; capacidades este-oeste (mTLS, SOAP, caché); costo y apertura frente a un ESB.	§10
D-14	Aurora PostgreSQL + DynamoDB + ElastiCache Redis	RDS MySQL / Oracle; Cassandra / DocumentDB; Memcached	Ajuste al patrón de acceso (polyglot persistence); HA y DR gestionadas multi-región; estándares abiertos sin licencias.	§10

ID	Decisión	Opciones evaluadas	Justificaciones principales	Sección
D-15	Amazon MSK (Kafka) + Debezium, con SQS/SNS complementarios	EventBridge; solo SQS/SNS	Durabilidad, orden y replay para auditoría; ecosistema CDC / outbox y Kafka Streams; SQS para colas simples.	§10
D-16	AWS como nube pública	Microsoft Azure	Menor latencia desde Ecuador y borde global; catálogo completo de replicación multi-región y biometría gestionada; madurez y gobernanza en banca.	§12
D-17	EKS + Graviton + Karpenter + Istio	ECS / Fargate; Linkerd; App Mesh	Ecosistema abierto para auto-healing y GitOps; costo-rendimiento; malla madura con políticas L7.	§12
D-18	DR multi-región warm standby (RTO ≤ 30 min, RPO ≤ 1 min)	Backup & restore; pilot light; activo-activo	Objetivos alineados con la norma; costo proporcionado (15–20 %); verificable con IaC y pruebas trimestrales.	§12
D-19	OpenTelemetry + Managed Prometheus / Grafana + CloudWatch / X-Ray	Datadog / New Relic; ELK autogestionado	Estándar abierto sin bloqueo; integración nativa y costo; residencia de datos y control de PII.	§14
D-20	Servicios gestionados + compromisos de largo plazo	Infraestructura autogestionada en EC2	Menor TCO al considerar personal y riesgo; elasticidad con Savings Plans y Graviton; certificaciones auditables.	§15

Confidencial – uso académico

17. Riesgos y hoja de ruta

17.1 Riesgos principales y mitigaciones

ID	Riesgo	Prob.	Impacto	Mitigación
R-01	Capacidad o latencia insuficiente de las APIs del Core para el volumen del canal digital.	Media	Alto	Vista de clientes frecuentes y caché; rate limiting hacia el Core; pruebas de carga tempranas; acuerdo de capacidad con el equipo del Core; CDC para reducir consultas.
R-02	El IdP existente no soporta PAR / DPoP / FAPI 2.0 o passkeys.	Media	Medio	Verificación temprana (spike); degradar a Code + PKCE con mTLS del cliente y refresh rotation; plan de actualización del producto o gateway de identidad intermedio.
R-03	Ataques de presentación / deepfakes en el Onboarding.	Media	Alto	Liveness activo con SDK oficial, atestación del dispositivo, límites de intentos, revisión manual, monitoreo de tasas de fraude, posibilidad de cambiar a proveedor certificado PAD nivel 2 (adaptador).
R-04	Fraude por toma de cuenta (phishing, SIM-swap, malware móvil).	Alta	Alto	Passkeys FIDO2 (phishing-resistentes), DPoP, atestación / RASP, step-up con vinculación dinámica, antifraude en línea, notificación por dos canales, enfriamiento de beneficiarios.
R-05	Inconsistencias entre la plataforma, el Core y la red (sagas incompletas).	Media	Alto	Máquina de estados persistida, timeouts y compensaciones, conciliación diaria automática, alertas de sagas en estado intermedio > X min.
R-06	Incumplimiento de plazos regulatorios (retención, reportes, notificación de brechas).	Baja	Alto	Controles como código (Config, Object Lock), calendario de cumplimiento, evidencias automatizadas, DPO y oficial de cumplimiento involucrados desde el diseño.
R-07	Sobrecostos por crecimiento no previsto (mensajería, egreso, logs).	Media	Medio	Presupuestos y alertas, políticas de retención, agrupación de notificaciones, revisión FinOps mensual.
R-08	Complejidad operativa de microservicios y malla.	Media	Medio	Plantillas de servicio (golden path), plataforma interna (Backstage), GitOps, observabilidad estándar, formación del equipo, empezar con pocos servicios y crecer.
R-09	Dependencia de un proveedor de nube.	Baja	Medio	Estándares abiertos (Kubernetes, PostgreSQL, Kafka, Redis, OpenTelemetry), arquitectura hexagonal con adaptadores, IaC portable; costos de salida evaluados en los ADR.

17.2 Hoja de ruta propuesta

Fase	Duración	Alcance	Hitos
0. Fundaciones	2 meses	Landing zone (Control Tower, cuentas, red, Direct Connect), EKS, malla, CI/CD, observabilidad, seguridad base, configuración del IdP (FAPI 2.0), spikes de integración con el Core, el CRM y la red ACH.	Plataforma lista; pruebas de latencia y de conectividad; ADRs aprobados.
1. Consulta y autenticación	3 meses	Capa de integración (Kong + conectores Core / CRM), servicios de Clientes, Productos y Saldos y Movimientos, BFFs, SPA y app con login (Code + PKCE, passkeys), auditoría, notificaciones de seguridad, clientes frecuentes.	Piloto con empleados; certificación de seguridad (pentest); SLOs medidos.
2. Transacciones	3 meses	Transferencias propias e interbancarias, pagos, beneficiarios, antifraude, step-up, notificación de movimientos por dos canales, conciliación.	Lanzamiento controlado (canary por segmentos); auditoría y reportes regulatorios operativos.
3. Onboarding y DR	2 meses	Onboarding facial (Textract, Rekognition, Registro Civil, AML), enrolamiento SCIM / FIDO2, región DR y primera prueba de conmutación, ingeniería de caos.	Captación digital habilitada; DR probado con RTO / RPO cumplidos.
4. Optimización continua	Continuo	FinOps, nuevos servicios (open finance, inversiones), mejoras de UX, revisiones Well-Architected y auditorías.	Revisiones trimestrales; error budgets; roadmap de producto.

18. Conclusiones

La arquitectura propuesta responde de manera integral a los requerimientos de BP y a los criterios de evaluación del ejercicio:

- **Requerimientos justificados y modelo C4 completo:** las vistas de contexto, contenedores y componentes — complementadas con diagramas de secuencia y de despliegue— documentan la solución desde el negocio hasta la infraestructura, y cada decisión relevante cuenta con opciones evaluadas y al menos dos justificaciones teóricas (sección 16).
- **Segmentación de responsabilidades y desacoplamiento:** microservicios por contexto de negocio, BFF por canal, capa de integración con ACL y bus de eventos garantizan que consultas, transacciones, auditoría, notificaciones y perfil digital evolucionen de forma independiente y sean reutilizables por nuevos canales.
- **Patrones aplicados con propósito:** Saga, Transactional Outbox, Idempotent Receiver, Circuit Breaker, Bulkhead, BFF, API Composition, CQRS / Materialized View, Cache-Aside, Decorator, Strategy, Observer, Chain of Responsibility, Anti-Corruption Layer y Token Handler resuelven problemas concretos de consistencia, resiliencia, rendimiento y seguridad.
- **Seguridad y cumplimiento como cimientos:** OAuth 2.0 / OIDC con Authorization Code + PKCE bajo el perfil FAPI 2.0, MFA con passkeys, step-up, Zero Trust, cifrado extremo a extremo, auditoría inmutable y controles alineados con la LOPDP, la normativa bancaria ecuatoriana y los estándares internacionales.
- **Onboarding integrado a la identidad:** el registro con reconocimiento facial desemboca de forma natural en el enrolamiento de credenciales del IdP, con un adaptador que permite cambiar de proveedor biométrico sin rediseñar el proceso.
- **Operación resiliente y eficiente en AWS:** alta disponibilidad Multi-AZ, DR warm standby multi-región con objetivos medibles, auto-healing, observabilidad estándar, entrega continua como código y una gestión de costos FinOps con una estimación referencial de USD 14.000–16.000 mensuales.

Los siguientes pasos recomendados son validar los supuestos críticos con pruebas de concepto (capacidades del IdP, APIs del Core, latencia desde Ecuador, proveedor biométrico), aprobar los ADR con los comités de Arquitectura, Seguridad y Cumplimiento, y arrancar la fase de fundaciones de la hoja de ruta.

Anexo A. Glosario

Término	Definición
ACL (Anti-Corruption Layer)	Capa que traduce entre el modelo de dominio propio y el de un sistema externo o legado, evitando que sus conceptos "contaminen" el dominio.
ACR / AMR	Claims OIDC que indican el nivel (Authentication Context Class Reference) y los métodos (Authentication Methods References) de autenticación usados.
AAL2 / AAL3	Niveles de aseguramiento de autenticación de NIST SP 800-63B: dos factores; dos factores con autenticador criptográfico de hardware resistente a phishing.
BFF (Backend for Frontend)	Servicio de backend dedicado a un canal (web, móvil) que adapta y compone las APIs de dominio para ese canal.
C4	Modelo de documentación de arquitectura de software en cuatro niveles: contexto, contenedores, componentes y código.
CDC (Change Data Capture)	Captura de cambios de una base de datos como flujo de eventos (p. ej. Debezium).
CQRS	Separación de los modelos de comando (escritura) y consulta (lectura).
DPoP	Demonstrating Proof of Possession (RFC 9449): liga un token OAuth a una llave del cliente.
FAPI 2.0	Perfil de seguridad de OAuth / OIDC para APIs financieras (OpenID Foundation).
FIDO2 / WebAuthn / Passkey	Estándar de autenticación con llaves criptográficas en el dispositivo, desbloqueadas por biometría o PIN; resistente a phishing.
Idempotencia	Propiedad por la que repetir una operación produce el mismo resultado que ejecutarla una sola vez.
ISO 20022	Estándar de mensajería financiera (p. ej. pacs.008 orden de crédito, pacs.002 informe de estado).
KYC / AML / PEP	Conozca a su cliente / prevención de lavado de activos / persona expuesta políticamente.
LOPDP	Ley Orgánica de Protección de Datos Personales del Ecuador.
mTLS	TLS mutuo: ambas partes se autentican con certificados.
Outbox transaccional	Patrón que escribe los eventos en una tabla dentro de la misma transacción del cambio de negocio para publicarlos después de forma confiable.
PAD (Presentation Attack Detection)	Detección de ataques de presentación (fotos, videos, máscaras) en biometría; ISO/IEC 30107-3 define su evaluación.
PAR	Pushed Authorization Requests (RFC 9126): los parámetros de autorización se envían por back-channel.
PKCE	Proof Key for Code Exchange (RFC 7636): protege el intercambio del código de autorización.
RPO / RTO	Pérdida máxima de datos tolerada / tiempo máximo de recuperación tolerado ante un desastre.
Saga	Secuencia de transacciones locales con compensaciones para mantener consistencia entre servicios.
SCIM 2.0	Estándar para aprovisionamiento de identidades entre sistemas.
SLO / error budget	Objetivo de nivel de servicio y margen de incumplimiento permitido que regula la velocidad de cambios.
Step-up	Autenticación reforzada exigida para operaciones de mayor riesgo dentro de una sesión.
Warm standby	Estrategia de DR con una copia funcional reducida del sistema en otra región, lista para escalar.
WORM	Write Once Read Many: almacenamiento inmutable (S3 Object Lock).
Zero Trust	Modelo de seguridad que no confía en la ubicación de red y verifica identidad y contexto en cada acceso.

Anexo B. Referencias y estándares

1. Brown, S. *The C4 model for visualising software architecture*. c4model.com.
2. IETF. RFC 6749 *The OAuth 2.0 Authorization Framework*; RFC 7636 *PKCE*; RFC 8252 *OAuth 2.0 for Native Apps*; RFC 7009 *Token Revocation*; RFC 9126 *Pushed Authorization Requests*; RFC 9449 *DPoP*; RFC 9470 *OAuth 2.0 Step-up Authentication Challenge Protocol*; RFC 9700 *Best Current Practice for OAuth 2.0 Security*; borrador *OAuth 2.0 for Browser-Based Apps*; borrador *OAuth 2.1*.
3. OpenID Foundation. *OpenID Connect Core 1.0*; *FAPI 2.0 Security Profile*.
4. FIDO Alliance / W3C. *FIDO2 / Web Authentication (WebAuthn)*.
5. NIST. SP 800-63-3 / 63A / 63B *Digital Identity Guidelines*; *Cybersecurity Framework 2.0*; SP 800-207 *Zero Trust Architecture*.
6. OWASP. *Application Security Verification Standard (ASVS) 4.0*; *Mobile Application Security Verification Standard (MASVS) 2.0*; *Top 10*; *API Security Top 10*; *Cheat Sheet Series*.
7. PCI Security Standards Council. *PCI DSS v4.0*.
8. ISO/IEC 27001:2022, 27002:2022, 22301:2019, 30107-3 (PAD); ISO 20022.
9. República del Ecuador. *Ley Orgánica de Protección de Datos Personales* (2021) y su Reglamento (2023); *Código Orgánico Monetario y Financiero*; *Ley Orgánica de Prevención, Detección y Erradicación del Delito de Lavado de Activos y del Financiamiento de Delitos*; *Ley de Comercio Electrónico, Firmas Electrónicas y Mensajes de Datos*; Superintendencia de Bancos, *Codificación de las Normas de la Superintendencia de Bancos* (gestión de riesgo operativo, seguridad de la información y canales electrónicos); Banco Central del Ecuador, normativa del Sistema de Pagos Interbancarios.
10. Superintendencia Financiera de Colombia, Circulares Externas 007/2018 y 029/2014; Ley 1581/2012; Unión Europea, PSD2 (SCA) y GDPR; FATF, Recomendaciones.
11. Amazon Web Services. *AWS Well-Architected Framework* y *Financial Services Industry Lens*; *Disaster Recovery of Workloads on AWS*; documentación de Amazon EKS, Aurora Global Database, DynamoDB Global Tables, Amazon MSK, ElastiCache Global Datastore, Amazon Rekognition Face Liveness, Amazon Textract, AWS KMS / CloudHSM, AWS Shield Advanced, AWS Control Tower.
12. Richardson, C. *Microservices Patterns* (Saga, Transactional Outbox, API Composition, CQRS, Idempotent Consumer). Manning, 2018.
13. Nygard, M. *Release It!* 2.ª ed. (Circuit Breaker, Bulkhead, Timeouts). Pragmatic Bookshelf, 2018.
14. Evans, E. *Domain-Driven Design* (Bounded Context, Anti-Corruption Layer). Addison-Wesley, 2003.
15. Gamma, E. et al. *Design Patterns* (Strategy, Decorator, Observer, Chain of Responsibility, Adapter, Facade). Addison-Wesley, 1994.
16. Hohpe, G.; Woolf, B. *Enterprise Integration Patterns* (Idempotent Receiver, Message Channel, Dead Letter Channel). Addison-Wesley, 2003.
17. Beyer, B. et al. *Site Reliability Engineering* (SLOs, error budgets, alerting). O'Reilly, 2016.
18. Bass, L.; Clements, P.; Kazman, R. *Software Architecture in Practice*, 4.ª ed. (tácticas de disponibilidad, rendimiento y seguridad). Addison-Wesley, 2021.

Anexo C. Inventario de diagramas y contenido del repositorio

Todos los diagramas se elaboraron como código con PlantUML y la librería estándar C4 (C4-PlantUML) más los iconos oficiales de AWS, lo que permite versionarlos y regenerarlos. El repositorio público contiene:

N.°	Diagrama	Archivo (docs/diagramas)	Sección
1	Contexto (C4 – Nivel 1)	01_contexto.puml / .png / .svg	§4
2	Contenedores – vista general (C4 – Nivel 2)	02_contenedores.puml	§5.1
3	Contenedores – detalle A: flujo síncrono	03_contenedores_sincrono.puml	§5.3
4	Contenedores – detalle B: flujo asíncrono	04_contenedores_asincrono.puml	§5.4
5	Componentes – Transferencias y Pagos + integración (C4 – Nivel 3)	05_componentes_transferencias.puml	§6.1
6	Componentes – Autenticación y autorización	06_componentes_autenticacion.puml	§6.2
7	Componentes – Onboarding facial	06b_componentes_onboarding.puml	§6.3
8	Componentes – Auditoría	07_componentes_auditoria.puml	§6.4
9	Componentes – Clientes frecuentes	08_componentes_clientes_frecuentes.puml	§6.5
10	Secuencia – Login App Móvil (Code + PKCE + PAR + DPoP)	09_secuencia_login_movil.puml	§8.3
11	Secuencia – Login Web SPA vía BFF	10_secuencia_login_spa.puml	§8.3
12	Secuencia – Onboarding facial	11_secuencia_onboarding.puml	§9.1
13	Secuencia – Transferencia interbancaria	12_secuencia_transferencia.puml	§10.4
14	Despliegue en AWS (C4 Deployment)	13_despliegue_aws.puml	§12.2
15	Monitoreo, observabilidad y auto-healing	14_observabilidad.puml	§14.1

Estructura del repositorio: `README.md` (descripción y enlace al PDF), `Arquitectura_Banca_Internet_BP_C4.pdf` (este documento), `docs/diagramas/` (fuentes .puml, PNG y SVG), `docs/adr/` (decisiones D-01 a D-20). Para regenerar los diagramas: `java -jar plantuml.jar -tpng docs/diagramas/*.puml` (requiere Java y Graphviz).